



*Asociación Profesional del Cuerpo Superior  
de Sistemas y Tecnologías de la Información  
de la Administración del Estado*

Temas Específicos para la preparación de la Oposición al Cuerpo Superior de Sistemas y Tecnologías de la Información de la Administración del Estado.

**TEMAS ESPECÍFICOS I: Organización y gestión de los sistemas de información**

**Tema 38. Auditoría Informática. Concepto y contenidos. Administración, planeamiento, organización, infraestructura técnica y prácticas operativas**

Editado por ASTIC en 2017 a partir del tema numerado anteriormente como:

- **Tema 31. Auditoría Informática I: Concepto y contenidos. Administración, planeamiento, organización, infraestructura técnica y prácticas operativas**

AUTOR: Eva María Ortiz Tovar y María Teresa Muñoz-Reja

Actualización 2013

## Sumario

- 36.01. Conceptos y contenidos.
  - 36.01.01 Introducción a la auditoría.
  - 36.01.02 Introducción al concepto de control en las organizaciones.
  - 36.01.03 Definiciones y clases de auditoría.
  - 36.01.04 Función de la auditoría de sistemas de información (estrategia).
  - 36.01.05 Auditoría de sistemas de información en la administración pública.
  - 36.01.06 Guía de Auditoría del Esquema Nacional de Seguridad.
- 36.02. Administración y planificación.
  - 36.02.01 Proceso de una auditoría
  - 36.02.02 Estándares y normas técnicas.
  - 36.02.03 Planificación.
  - 36.02.04 Auditoría asistida por ordenador y software de auditoría Informatizada (CAAT).
- 36.03. Organización, infraestructura técnica.
  - 36.03.01 Esquema Organizativo de la Función de Auditoría. Modelos Organizativos.
  - 36.03.02 El auditor informático. Perfil técnico. Ética profesional.
- 36.04. Prácticas operativas.
  - 36.04.01 El proceso de la auditoría de sistemas de información (Planificación de la actuación, formalización del inicio, trabajos de Campo, evaluación de la información, comunicación de los resultados, seguimiento).
  - 36.04.02 Guías de Auditoría de los sistemas de información (guion, puntos de control).
  - 36.04.03 Informes de auditoría.
- 36.05. Bibliografía.

### 36.01. Conceptos y contenidos

La Auditoría de los Sistemas de Información debe entenderse como una herramienta más que ayudará a las organizaciones a supervisar su sistema de control, a gestionar sus riesgos; su objetivo es contribuir a establecer un clima de confianza en el uso de las tecnologías de la información y de las comunicaciones y a reforzar la gestión de su seguridad y calidad.

La revolución tecnológica ha dado lugar a lo que se ha llamado el cambio de la Sociedad Industrial a la Sociedad de la Información, ello conlleva la cada vez mayor dependencia de las organizaciones de la tecnología. El uso de las tecnologías marca la posición de competitividad de las organizaciones.

La información, junto con el conocimiento, es uno de los activos más importantes, así que los requerimientos de calidad, controles y seguridad son indispensables. Los responsables de las organizaciones tienen que establecer controles internos ya que los procesos de negocio se apoyan cada vez más en los procesos tecnológicos.

En este punto cuando la Organización ISACA (Information Systems Audit and Control Association), a través de su Fundación publicó a finales de 1995 CobiT (Control Objectives for Information and Related Technology) como una definición de estándares y conducta profesional para la gestión y control de los Sistemas de Información. Destaca el modelo de buenas prácticas como un marco referencia para los auditores donde los procesos de negocio juegan un papel fundamental en cuanto a su dependencia de las tecnologías de la información y de las comunicaciones.

Para aclarar el concepto de auditoría informática se muestran algunas definiciones:

La **auditoría informática es un proceso** llevado a cabo por profesionales especialmente capacitados para el efecto, y que consiste en recoger, agrupar y evaluar evidencias para determinar si un sistema de información salvaguarda el activo empresarial, mantiene la integridad de los datos, lleva a cabo eficazmente los fines de la organización, utiliza eficientemente los recursos, y cumple con las leyes y regulaciones establecidas. Permiten detectar de forma sistemática el uso de los recursos y los flujos de información dentro de una organización y determinar qué información es crítica para el cumplimiento de su misión y objetivos, identificando necesidades, duplicidades, costes, valor y barreras, que obstaculizan flujos de información eficientes.

La auditoría informática principalmente puede ser de dos tipos:

- Auditoría Interna: que se hace adentro de la empresa; sin contratar a personas ajenas a la organización.
- Auditoría Externa: aquella en la cual la empresa contrata a personas de afuera para que haga la auditoría en su empresa.

Auditar consiste principalmente en estudiar los mecanismos de control que están implantados en una empresa u organización, determinando si los mismos son adecuados y cumplen unos determinados objetivos o estrategias, estableciendo los cambios que se deberían realizar para la consecución de los mismos. Los mecanismos de control pueden ser directivos, preventivos, de detección, correctivos o de recuperación ante una contingencia.

Los objetivos de la auditoría Informática son:

- El análisis de la eficiencia de los Sistemas Informáticos
- La verificación del cumplimiento de la Normativa en este ámbito
- La revisión de la eficaz gestión de los recursos informáticos.

Sus beneficios son:

- Mejora la imagen pública.
- Confianza en los usuarios sobre la seguridad y control de los servicios de TI.
- Optimiza las relaciones internas y del clima de trabajo.
- Disminuye los costos de la mala calidad (reprocesos, rechazos, reclamos, entre otros).
- Genera un balance de los riesgos en TI.
- Realiza un control de la inversión en un entorno de TI, a menudo impredecible.

Otra definición establece que la auditoría informática se preocupa de ejercer control sistemático tendiente a:

- Detectar evidencias de riesgos y/o problemas en el apoyo informático a los procesos de negocio originados en un mal manejo informático y/o del control.
- Sugerir mejoras a los procedimientos preventivos de detección y correctivos.

Por lo tanto, la auditoría informática sería un **instrumento de control** utilizado para asegurar el adecuado uso, protección y control de los Elementos Informáticos, y su contribución a la protección del patrimonio de la empresa, y apoyo al logro de los objetivos.

Objetivos:

- Uso eficiente y eficaz de protección y control de los elementos informáticos.
- Protección del patrimonio de la empresa. Esto se logra con buena información de apoyo para la planificación y control de los activos, así como a las funciones financieras.
- Alineamiento de la información a las áreas críticas del negocio para lograr los objetivos. Este es el objetivo más general y relevante<sup>1</sup>.

### 36.01.01 Introducción a la auditoría

Desde los inicios de la humanidad las distintas culturas han dado gran importancia a los temas de contabilidad, y por tanto han necesitado medios para verificar los registros de los mismos, es decir, de la auditoría. De hecho, se piensa que la invención de la escritura surge como respuesta a la necesidad de auditar [Flesher, 1993].

Aunque la Auditoría de los Sistemas de Información<sup>2</sup> es una auditoría parcial de la organización, la importancia estratégica y el carácter transversal de las TIC "tecnologías de la información y las comunicaciones" en el mundo moderno confieren a este tipo de auditoría una relevancia creciente.

Resumiendo, las grandes revoluciones culturales que implican nuevos modelos de sociedad en la historia podemos citar las siguientes:

---

<sup>1</sup> Objetivo que recurrentemente aparece en todas las definiciones y buenas prácticas para el desarrollo de las auditorías informáticas, y principal objetivo de CobiT.

<sup>2</sup> La auditoría de sistemas de información, auditoría informática o auditoría de sistemas son términos sinónimos en este tema (se reflejarán únicamente en este momento las diferencias de matiz entre ellos); la auditoría de sistemas de información incluye a la auditoría informática, y consiste en el examen de los sistemas de información de las organizaciones con el objetivo de facilitar la consecución de los objetivos que persiguen cumplir.

ISACA nos presenta una definición más amplia: " la auditoría de los sistemas de información es cualquier auditoría que abarca la revisión y evaluación de todos los aspectos de los sistemas automáticos de procesamiento de la información (o una parte de ellos), incluidos los procedimientos no automáticos relacionados con ellos y las interfaces correspondientes".

En la auditoría por medio del ordenador, se emplea el ordenador como herramienta. Ej. Auditoría contable. En la auditoría Informática, el objeto a auditar es un producto o proceso informático y su gestión. La auditoría informática con el ordenador es el uso del ordenador como herramienta del auditor informático.

- Revolución neolítica, se produjo la transformación de una Sociedad nómada a sedentaria, el objeto más importante para esta transformación fue el arado y la materia prima los alimentos.
- Revolución industrial, transformándose la Sociedad rural en urbana, el objeto más representativo del cambio fue la máquina de vapor y la materia prima la energía.
- Revolución de la información, conlleva la transformación de la sociedad industrial a la sociedad de la información, el objeto fundamental del cambio ha sido el ordenador y la materia prima la información. Entre las características más destacables de esta "revolución informática" podemos citar algunas de carácter social (globalizaciones económica y cultural, nuevas leyes "protección datos, propiedad intelectual, reformas código penal contemplando la informática, firma digital...", y empresarial (dependencia de las TIC, automatización de funciones, reducción de costes, nuevos modelos de negocio (ej. Bancos...)) La diferencia más notable respecto a los otros hitos históricos ha sido la alta velocidad de transición. Ninguna revolución fue tan vertiginosa en toda la Historia.

En las organizaciones, la información y la tecnología que la soporta representan los activos más valiosos. La productividad de cualquier organización depende del funcionamiento ininterrumpido de sus sistemas de información, lo que conlleva la transformación de todo el entorno en un proceso crítico adicional.

Es necesario contar pues con una efectiva administración de los riesgos asociados con las TIC.

El análisis de estos aspectos nos indica el rol básico que debe desempeñar la función de la Auditoría de los Sistemas de Información<sup>1</sup> en una organización: **supervisión de los controles implementados y determinación de la eficiencia de los mismos.**

El problema real es identificar correctamente los objetivos<sup>3</sup> que debe cumplir el área de informática, ya que suelen ser difíciles de establecer, podemos resolverse parcialmente este problema basándonos en los objetivos que debe cumplir la organización en su conjunto (el área de informática dado su carácter transversal puede adoptarlos perfectamente) o haciendo que los objetivos asuman la forma de compromisos que deben ser satisfechos en unos plazos y con una calidad predeterminada.

Repasando la evolución a lo largo del tiempo la relación entre auditoría y tecnologías de la información. En un primer momento la orientación era la detección y prevención del fraude y errores; después se usó para evaluar situación financiera (la detección y prevención del fraude y errores era un objetivo menor).

Simultáneamente se ha producido una evolución metodología:

- Hasta s. XIX se realiza un examen exhaustivo;
- Después s. XIX: se emplean técnicas de muestreo de datos, y revisión de los controles internos.

La Aparición del concepto tiene lugar en las sociedades antiguas (Egipto, Roma). Aparecen las figuras de terratenientes /aparceros. Se producía la **Liquidación verbal de cuentas** con los "**auditores**" (los que oyen). Durante la edad media aparecen en Castilla los "**veedores**" de

---

<sup>3</sup> objetivos: expresan los intereses comunes y guían las decisiones; deben ser alcanzables y susceptibles de cuantificación o al menos de concreción.

.- metas: son los resultados esperados de un proceso.

**cuentas.** En el s. XVIII, surge la Sociedad Anónima en Holanda; aparece el concepto de separación de la propiedad y una nueva profesión, **la gerencia**. Aparecen también los fraudes para aparentar buen funcionamiento, lo que hace necesarios:

1. La creación de un método y de un sistema normalizado de contabilidad y
2. Expertos independientes para controlar a los gestores y revisar las cuentas. En 1862, la Ley Británica de Sociedades Anónimas, reconoce la **auditoría** como profesión. En 1880 se crea, en Inglaterra, la Primera Sociedad de Auditores. Hasta 1905 la auditoría floreció como profesión en Inglaterra. En 1900 se introduce en EE.UU. En 1912 aparece en España con el **Colegio de Contadores Públicos**. En 1954 se crea el primer sistema de contabilidad informatizada. En esta época, la Auditoría gira alrededor del ordenador (se comprobaban las salidas en función de las entradas). En los años 60 la atención se centra en el CPD (Centro de Proceso de Datos). Se produce una revolución cuantitativa: muchas operaciones, gestión versus Propiedad; se presenta un nuevo enfoque: es imposible verificar TODA la información por lo que se analizan **extractos**. En los años 70 el foco se dirige a los programas y su lógica interna. En 1977, se publica la Primera edición de Control Objectives, antecesor de **CobiT** (Control Objectives for Information and Related Technology).

A partir de 1950, la informática se convierte en una herramienta muy importante en las labores de la auditoría financiera, ya que permite llevar a cabo de forma rápida y precisa, operaciones que manualmente consumirían demasiados recursos. Comienza la auditoría con ordenador, que todavía no se puede considerar auditoría informática, sino más bien el uso de un ordenador como herramienta del auditor financiero.

Como se comentaba en la introducción la información es uno de los activos más importantes de las empresas y su principal ventaja estratégica. Las empresas invierten grandes cantidades de dinero y tiempo en la creación de sistemas de información que les permita ser más productivos y con procesos de una mayor calidad. Por lo que los temas relativos a la auditoría informática cobran cada vez más relevancia tanto en el ámbito nacional como en el internacional. De esta importancia nace la necesidad de que la información sea protegida por el derecho y, por lo tanto, dicha protección se regule en el ordenamiento jurídico:

- La Ley Orgánica 15/1999 de 13 de diciembre de protección de datos de carácter personal, y su real decreto de desarrollo (Real Decreto 1720/2007, de 21 de diciembre, por el que se aprueba el Reglamento de desarrollo de la Ley Orgánica 15/1999.
- Ley Orgánica 10/1995 de 23 de noviembre que aprueba el nuevo Código Penal.
- Texto Refundido de la Ley de la Propiedad Intelectual aprobado por el Real Decreto Legislativo 1/1996 de 12 de abril.
- La Ley 11/2007, de 22 de junio, de Acceso Electrónico de los Ciudadanos a los Servicios Públicos, derogada por las nuevas leyes 39/2015 y 40/2015. Real Decreto 1671/2009, de 6 de noviembre, por el que se desarrolla parcialmente la Ley 11/2007, de 22 de junio, de acceso electrónico de los ciudadanos a los servicios públicos. Real Decreto 4/2010, de 8 de enero (BOE de 28 de enero), por el que se regula el Esquema Nacional de Interoperabilidad en el ámbito de la administración electrónica. Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica.

También el perfil del auditor ha sufrido paralelamente una evolución temporal:

- Al principio el auditor, casi siempre un auditor de cuentas, se limitaba a revisar la información que obtenía del ordenador con una metodología semejante a la del resto de actuaciones que desarrollaba.

- Posteriormente, el auditor comienza a emplear técnicas específicas para analizar los sistemas de información, como las pistas o trazas de auditoría<sup>4</sup>.
- Paulatinamente, el auditor se apoya cada vez más en el ordenador como instrumento de trabajo, se incorporan herramientas que facilitan su actividad profesional automatizando ciertas tareas; en una fase posterior estas herramientas permiten acceder directamente a los sistemas de información investigados y desarrollar en ellos, de forma completa o parcial, tareas de comprobación. El auditor comienza a dominar lenguajes de programación y consulta.
- Finalmente, el auditor aplica directamente técnicas de auditoría específicas a la verificación del cumplimiento de objetivos de los servicios informáticos, con objeto de determinar la eficacia y eficiencia de su funcionamiento. Se usan medios informatizados para los procedimientos de auditoría (CAAT, Computed-Assisted Audit Techniques).

La auditoría informática debe cumplir cinco funciones:

1. Velar por la **eficacia y eficiencia del sistema informático**, de forma que se alcancen con el menor coste posible los objetivos que le han sido establecidos.
2. Verificar el **cumplimiento de las normas y estándares** vigentes en la organización.
3. Verificar **la calidad de los sistemas de información** y proponer mejoras en los mismos. La Administración General del Estado ha fijado por Real Decreto 29/2005 un marco general para la mejora de la calidad compuesto por varios programas de calidad.
4. Supervisar los **mecanismos de control interno** establecidos en los centros de proceso de datos y en la organización en su conjunto para proteger los recursos informáticos humanos y materiales y para mantener la integridad de los datos.
5. Comprobar e impulsar **la seguridad de los sistemas de información** (es decir, garantizar la disponibilidad de las infraestructuras de información, la integridad y la confidencialidad de los datos, su autenticidad y la identidad de las partes que los usan).

Las **tres normas básicas** en la auditoría de los sistemas de información son:

- Planificación y supervisión
- Estudio y evaluación del sistema de control interno
- Obtención de evidencia suficiente y adecuada (justificación del trabajo realizado y la opinión expresada)

### **36.01.02 Introducción al concepto de control en las organizaciones**

La planificación y el control se incluyen como funciones directivas desde las reflexiones de los primeros teóricos de la organización como Fayol. El Control Interno Informático controla que todas las actividades del SI (Sistema de Información) sean realizadas cumpliendo los procedimientos, estándares y normas de la dirección, así como las normas legales.

---

<sup>4</sup> las pistas o trazas de auditoría consisten en registros que recoge el sistema informático sobre las operaciones efectuadas, y que permiten contrastar los resultados procedentes de dicho sistema con los documentos originales a los que se refieren.

Encontramos pues otra definición de **Auditoría Informática**: el Proceso de recoger, agrupar y evaluar evidencias para determinar si un sistema informatizado salvaguarda los activos, mantiene la integridad de los datos, cumple eficazmente los fines de la organización, y hace uso eficiente de los recursos.

El auditor es responsable de informar a la Dirección de la organización sobre el diseño y funcionamiento de los controles implantados y sobre la fiabilidad de la información suministrada.

El **Control Interno** es cualquier actividad manual o automática empleada para prevenir y corregir errores que puedan afectar al funcionamiento de un sistema en relación con la consecución de sus objetivos

El control consiste en un **proceso<sup>5</sup> de observación y medida** que compara **sistemáticamente** los objetivos con los resultados y que tiene la capacidad necesaria para regular los sistemas con la intención de que sean alcanzados los objetivos.

Los controles deberían ser:

- Simples (no siempre es posible, en este caso, con la "mínima complejidad necesaria") y fiables. Ej. Copia de seguridad comprimida, verificar extracción;
- Revisables (establecer procedimientos o fechas);
- Adecuados, ej. Entrada al sistema con login / password y
- Rentables (el coste menor que el beneficio).

Los controles pueden clasificarse atendiendo a diferentes características:

|                                       |                                                                                                                                                                                                                                                                                           |
|---------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Por <b>el momento en que actúan</b> : | <ul style="list-style-type: none"> <li>• <b>Preventivos</b>: "a priori", ej. Impedir accesos no autorizados,</li> <li>• <b>Reactivos</b>: "a posteriori",</li> <li>• <b>Concurrente o concomitante</b> (establecido durante la realización del proceso que se observa y mide).</li> </ul> |
| Por su <b>frecuencia</b> :            | <ul style="list-style-type: none"> <li>• Control <b>continuo</b>,</li> <li>• Control <b>periódico o esporádico</b>.</li> </ul>                                                                                                                                                            |
| Por su <b>naturaleza</b> :            | <ul style="list-style-type: none"> <li>• <b>Generales</b> (organizativos y operativos, de desarrollo y mantenimiento de aplicaciones, de hardware, de software, de acceso, de procedimiento).</li> <li>• <b>De aplicación</b> (controles de entrada, de proceso, de salida).</li> </ul>   |

Según otra clasificación los controles pueden ser de **desarrollo** (comprueba que el resultado obtenido concuerda con las especificaciones iniciales), de **proceso** (asegura que la explotación

---

<sup>5</sup> proceso: conjunto de actividades que obtiene unos resultados – "outputs" a partir de unos recursos – inputs.

Se realiza con las versiones adecuadas de los programas y de los datos) y de **continuidad** (determina que se evita la pérdida o corrupción de información, efectuando las salvaguardas y recuperaciones necesarias).

Además, podemos hablar de controles **Detectivos**, ej. Registro de intentos de acceso, análisis de logs; o **Correctivos**: facilitar la vuelta a la normalidad (ej. documentar el proceso de recuperación desde una copia de seguridad).

Dada la inmediatez de los procesos informatizados es necesario implementar controles automáticos incorporados en los propios procesos de los sistemas de información, son, **alarmas** que actúan ante la aparición de acontecimientos que pueden suponer un riesgo para la consecución de los objetivos.

El control aporta confianza al garantizar que la información que la organización hace pública reúne unas características determinadas de veracidad y fiabilidad, ofreciendo una imagen fiel de sí misma.

Como reacción ante escándalos cuyos indicios no fueron debidamente detectados o evaluados, se publica en 1992 el informe COSO<sup>6</sup>. Este informe define el control interno como "un proceso efectuado por el Consejo de Administración, la dirección y el resto del personal de una entidad, diseñado con el objeto de proporcionar un grado de seguridad razonable en cuanto a la consecución de objetivos dentro de las siguientes categorías:

- eficacia y eficiencia de las operaciones,
- fiabilidad de las operaciones financieras,
- cumplimiento de las leyes y normas que le sean aplicables".

El control interno en una organización se extiende, como ya se ha indicado, a todas las funciones informáticas: entrada de datos, desarrollo y mantenimiento de aplicaciones, software de sistemas, administración de base de datos, gestión de contenidos, explotación o producción, comunicaciones, administración y gestión de redes, seguridad, instalación de equipos y gestión del inventario, asistencia y soporte a usuarios, administración, dirección ...

En ocasiones puede ser necesario disponer de un **control compensatorio**, cuando no esté previsto un control, cuando su coste lo haga inabordable, cuando no esté efectivamente implantado o cuando falle su aplicación.

En el apartado **33.01.05** se realiza una pequeña revisión sobre el control en el ámbito de la administración pública española, haciendo un desarrollo más amplio en el punto **33.01.06** donde se explica la Guía de Auditoría desarrollada en el contexto del Esquema Nacional de Seguridad.

---

<sup>6</sup> Nuevo concepto de control interno donde se brinda una estructura común el cual es documentado en el denominado informe COSO. SOX es un sistema de implementación de control interno para la certificación de las empresas mediante la verificación y análisis del correcto funcionamiento de sus procedimientos, información confiable y gestiones oportunas. La Ley Sarbanes-Oxley es una Ley federal de Estados Unidos que ha generado mucha controversia, ya que esta Ley va en respuesta a los escándalos financieros de algunas grandes corporaciones, entre los que se incluyen los casos que afectan a Enron, Tyco International, WorldCom y Peregrine Systems. Estos escándalos hicieron caer la confianza de la opinión pública en los sistemas de contabilidad y auditoría. En 1992, COSO publicó el Sistema Integrado de Control Interno, un informe que establece una definición común de control interno y proporciona un estándar mediante el cual las organizaciones pueden evaluar y mejorar sus sistemas de control. Utilización de COSO, modelo del Gobierno Corporativo, y de COBIT, modelo del Gobierno de la Tecnología de la Información, para lograr conformidad con la ley SARBANES-OXLEY

### 36.01.03 Definiciones y clases de auditoría

Un proceso de **auditoría** consiste en la realización de un **examen metódico** de la **situación de una organización** en **cooperación con los interesados** con el fin de **verificar la concordancia de la realidad con lo preestablecido** y la **adecuación de los resultados obtenidos** por la organización **a los objetivos perseguidos** por la misma.

Los objetivos de control y auditoría están directamente relacionados: **los auditores supervisan el sistema de control interno** de la organización, detectando las debilidades que presenten los controles establecidos y recomendando actuaciones necesarias para reforzarlos; durante el desarrollo de la auditoría los **auditores suelen reproducir los controles ordinarios establecidos por la organización** para determinar su efectividad además de realizar actividades de control adicionales.

Relacionando las clases de auditoría existentes en función de las clasificaciones más utilizadas:

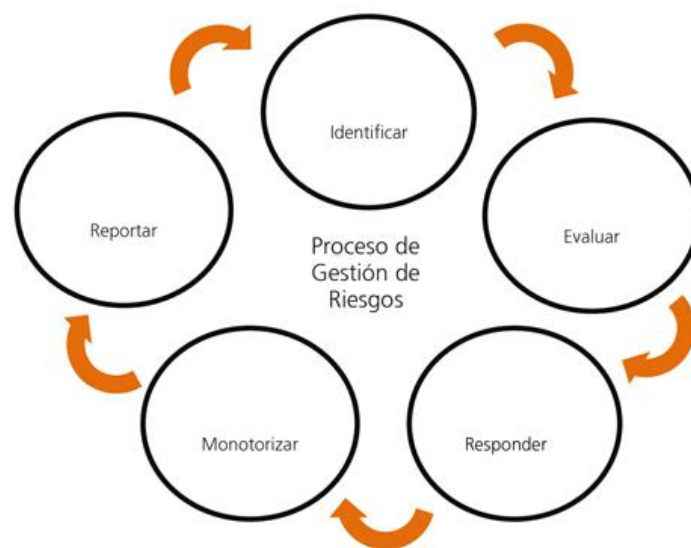
|                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Según el <b>sujeto</b> que la realiza: | <ul style="list-style-type: none"><li>• <b>Interna</b> (realizada por personal de la propia entidad)</li><li>• <b>Externa</b> (la realizan profesionales ajenos a la entidad).</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Según su <b>amplitud</b> :             | <ul style="list-style-type: none"><li>• <b>Total</b> (afecta a toda la organización),</li><li>• <b>Parcial</b> (se refiere sólo a determinados departamentos o actividades de la organización, restringiéndose en función de su ámbito territorial o funcional).</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Según su <b>frecuencia</b> :           | <ul style="list-style-type: none"><li>• <b>Periódica</b>, por ejemplo, anual o bienal (por ejemplo, tal y como estable la normativa de protección de datos o el Esquema Nacional de Seguridad), u</li><li>• <b>Ocasional</b>.</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Según su <b>contenido y fines</b> :    | <ul style="list-style-type: none"><li>• <b>Auditorías de regularidad</b> (auditorías de cumplimiento, orientadas a verificar el cumplimiento de la normativa aplicable; o auditorías financieras o contables, emiten un juicio sobre el estado financiero de la entidad).</li><li>• <b>Auditorías operativas o de gestión</b> (evalúan la eficacia en la consecución de objetivos y la eficiencia en los recursos empleados para alcanzarlos).</li><li>• <b>Auditorías forenses</b> (especializadas en descubrir fraudes y delitos, en obtener evidencias válidas para su uso por las autoridades competente, policiales o judiciales).</li><li>• <b>Auditorías de los sistemas de información</b> (realizan el examen y verificación del correcto funcionamiento y control del sistema informático de la organización).</li></ul> |

### 36.01.04 Función de la auditoría de sistemas de información (estrategia)

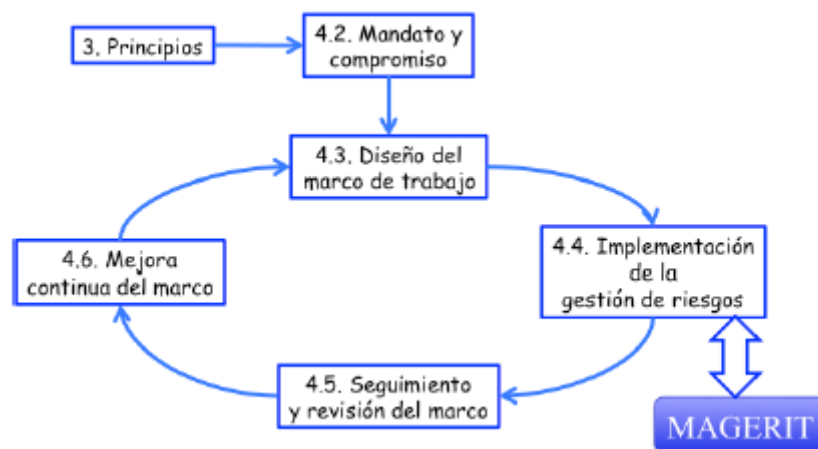
Las organizaciones competitivas son aquellas que comprenden y gestionan los riesgos asociados con la implementación de las nuevas tecnologías. En ellas, el equipo directivo

necesita poder apreciar y poseer un conocimiento básico de los riesgos y los límites de las TIC con objeto de proveer una dirección eficaz y los controles adecuados. Debe pronunciarse sobre cuál es la inversión razonable en seguridad y control, y cómo balancear el riesgo y el control de las inversiones, es imprescindible que el órgano de dirección entienda la implicación de una gestión de riesgos en general, y los relacionados con las TIC en particular, y aseguren el establecimiento de un sistema de control interno apropiado para la organización que dirige. Ya no se habla exclusivamente de la Seguridad de la Información o de la seguridad informática, el concepto que se ha incorporado más allá del análisis de riesgos es la **Gestión del Riesgo como un proceso estratégico en el ámbito empresarial**, donde la Dirección no sólo conoce los riesgos a los que su negocio está sometido, sino que los asume decidiendo hasta dónde está dispuesta a realizar una inversión para minimizar su impacto.

La gestión del riesgo es un requisito previo para poder realizar cualquier tipo de auditoría que la organización tenga definida, documentada, pública para todo el personal y aplicada, una política de control. Si un ciclo típico de análisis y gestión de riesgos podría ser:



Siguiendo la terminología de la normativa ISO 31000, MAGERIT v3, responde a lo que se denomina "Proceso de Gestión de los Riesgos", según la siguiente figura;



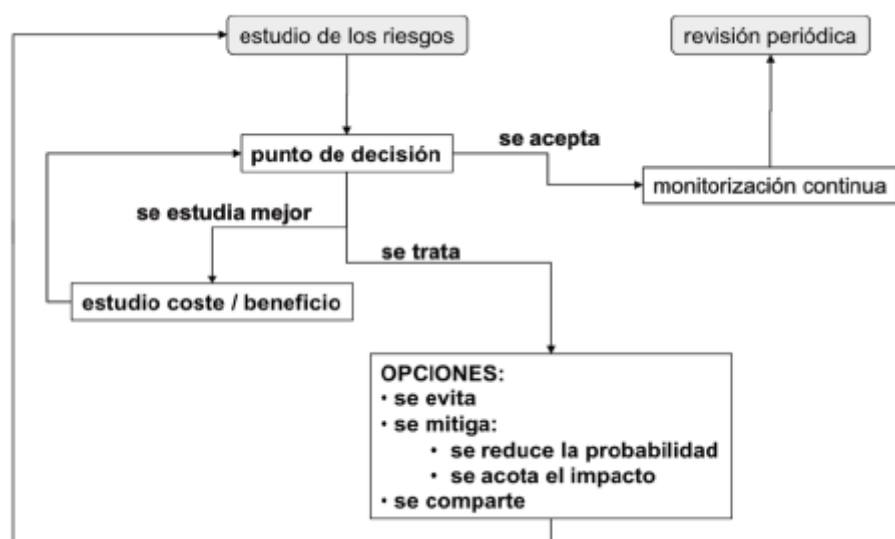
El análisis de riesgos determina impactos y riesgos. Los impactos recogen daños absolutos, independientemente de que sea más o menos probable que se dé la circunstancia. En cambio,

el riesgo pondera la probabilidad de que ocurra. El impacto refleja el daño posible (lo peor que puede ocurrir), mientras que el riesgo refleja el daño probable (lo que probablemente ocurra). A partir del análisis se dispone de información para tomar decisiones conociendo lo que se quiere proteger (activos valorados), de qué se quiere proteger (amenazas valoradas) y qué se ha hecho hasta el momento para protegerlo (salvaguardas valoradas).

A partir de aquí, las decisiones son de los órganos de gobierno de la Organización que actuarán en 2 pasos:

- Paso 1: evaluación
- Paso 2: tratamiento

La siguiente figura resume las posibles decisiones que se pueden tomar tras haber estudiado los riesgos. La caja 'estudio de los riesgos' pretende combinar el análisis con la evaluación.



En el ciclo de gestión de control la auditoría tiene la misión de analizar la implementación de los controles y corregir la gestión con la propuesta de mejoras. En la siguiente figura se esquematiza el ciclo de gestión de control (como ejemplo se recoge el ciclo de Deming<sup>7</sup>):

<sup>7</sup> Wikipedia: El ciclo de Deming, también conocido como círculo PDCA (de Edwards Deming), es una estrategia de mejora continua de la calidad en la administración de una organización. Está basada en un concepto ideado por Walter A. Shewhart. También se denomina espiral de mejora continua. Es muy utilizado por los sistemas de administración de la calidad. Las siglas, PDCA son el acrónimo de Plan, Do, Check, Act (Planificar, Hacer, Verificar, Actuar), los cuatro pasos de la estrategia. Los resultados de la implementación de este ciclo permiten a las empresas una mejora integral de la competitividad, de los productos y servicios, mejorando continuamente la calidad, reduciendo los costos, optimizando la productividad, reduciendo los precios, incrementando la participación del mercado y aumentando la rentabilidad de la empresa u organización.



En este contexto el proceso de la Auditoría se considera como uno de los procesos estratégicos en la organización, tal y como considera cualquier buena práctica (ITIL, CobIT) o estándar de gestión (ISO 9000 Gestión de Calidad).

Como proceso estratégico, el procedimiento de Auditoría se encuadraría en la pirámide documental de la organización.



Repasando alguno de los términos:

- **Políticas:** Declaración de intenciones de alto nivel, refleja los objetivos de la organización (qué y por qué), deben estar debidamente documentadas y establecer criterios de medición de resultados. Deben ser aprobadas por la alta dirección de la organización, perdurables en el tiempo (mantenerse al margen de la tecnología empleada) y conocidas por toda la organización. Como ejemplo de políticas TIC podemos considerar aquellas que definan aspectos de: Adquisiciones, Seguridad, Personal, etc.
- **Normativas:** Reglas generales que desarrollan las políticas de alto nivel, de obligada aplicación para las personas de la organización. Serán definidas por el órgano de dirección responsable de su supervisión. Se ajustarán al despliegue tecnológico, y serán conocidas por los usuarios de los sistemas. Por ejemplo, se podrán tener definidas o adoptadas normas sobre: control de presencia, control de acceso a los sistemas de información, estándares y normas técnicas del mercado que sean de aplicación, requerimientos legales, etc.

- **Procedimientos:** Señalan el marco de actuación en los distintos campos de las TIC para resolver situaciones concretas. Deben ser desarrollados por la unidad responsable de su implementación y estar ajustados a normas, estar documentados y tener unos contenidos mínimos ajustados a la materia, deben mantenerse actualizados y han de ser conocidos por los encargados de ejecutarlos y por los usuarios. Como ejemplo de procedimientos, se podrán tener sobre: gestión de usuarios, resolución incidencias, copias de seguridad, pruebas a realizar en desarrollos, etc.
- **Instrucciones:** Detallan técnicamente la forma precisa de actuar para implementar un procedimiento, señalando los pasos de obligado cumplimiento que deben seguirse. Deben estar documentadas y ser conocidas por los técnicos responsables. Como ejemplo de instrucciones señalamos las relativas a: seguimiento actividad vérica, instalación de actualizaciones, restablecimiento de sistemas, backups, etc.

### 36.01.05 Auditoría de sistemas de información en la Administración Pública

La función de control de la Administración Pública española se desarrolla en tres ámbitos: - **control político** (ejercido por el Parlamento), - **control judicial** (ejercido por los Tribunales de Justicia) y - **control administrativo** (ejercido por órganos administrativos). Centrándonos en el control administrativo nos encontramos los siguientes órganos especializados:

- **Tribunal de Cuentas** (órgano supremo fiscalizador de las cuentas y de la gestión económica del Estado y del sector público), controla la actividad económica y presupuestaria. Es un órgano externo, de carácter administrativo que también tiene atribuidas funciones de alcance contable, y cuyo destinatario principal es el Parlamento.
- **Intervención General de la Administración del Estado (IGAE)**, es un órgano interno de la Administración que examina la gestión del gasto público por parte de los organismos gestores. La IGAE comenzó examinando exclusivamente los aspectos legal y financiero del gasto público, pero desde 1984 debe elaborar anualmente un **Plan de Auditorías**. Sus actividades en este campo están minuciosamente regladas. Las Normas Técnicas de Auditoría Pública constituyen el núcleo de sus procedimientos de trabajo, clasifican sus actuaciones en dos grandes grupos: - **auditorías de regularidad** y **auditorías operativas**. La Ley General Presupuestaria de 47/2003, de 26 de noviembre, refrenda el papel de la IGAE en el control interno, delimitando sus funciones interventora, de control financiero permanente y de auditoría pública.
- **Inspecciones Generales de los Servicios**, según Real Decreto 799/2005, de 15 de julio, son los órganos de la Administración General del Estado especializados en el control interno y en la evaluación de los servicios de cada uno de los Ministerios y de sus organismos públicos dependientes. Su función es supervisar el funcionamiento de los órganos administrativos, lo que incluye el seguimiento de objetivos y el análisis de riesgos y debilidades. En el artículo 2 del RD se recogen entre sus funciones, la de realizar **auditorías internas**. En el Real Decreto 951/2005 de 29 de julio, por el que se establece el marco general para la mejora de la calidad en la Administración General del Estado, se les atribuyen competencias en la evaluación de calidad de las organizaciones. La coordinación de la actividad de las Inspecciones Generales de los distintos Ministerios se realiza por un órgano colegiado, la Comisión Coordinadora de Inspecciones Generales de Servicios.
- **Inspección General del Ministerio de Hacienda y Administraciones Públicas y Servicio de Auditoría interna de la Agencia Tributaria**, sus procedimientos de actuación están regulados por el Real Decreto 1733/1998. A la **Inspección General** le corresponde la evaluación y el control del funcionamiento interno del Ministerio de Economía y Hacienda, la inspección del modo y eficacia con que se gestionan los tributos cedidos a las Comunidades Autónomas y la coordinación de la alta inspección

referente a la aplicación de los sistemas fiscales concertados y convenidos. A la **Agencia Estatal de Administración Tributaria** (AEAT) le corresponde facilitar a los contribuyentes el cumplimiento de sus obligaciones, recaudando los tributos exigibles y desarrollando los programas de control fiscal y prevención del fraude y la elusión fiscal. La AEAT dispone desde su creación (Ley 31/1990 de los Presupuestos Generales del Estado para 1991) de un **Servicio de Auditoría Interna** (SA), con rango de dirección adjunta, que desempeña funciones de control interno, evaluación de los sistemas de seguridad y de control interno de la AEAT, apoyo a los órganos rectores de la Agencia en el cumplimiento de los objetivos, y presupuesto, análisis y seguimiento de los ingresos tributarios. El Servicio de Auditoría Interna también se ocupa de la prevención y detección de las conductas irregulares de los empleados de la organización, además de formar parte de la Unidad Operativa del Consejo de Defensa del Contribuyente, que atiende las quejas y sugerencias y hace efectivo el derecho de los ciudadanos a expresar su disconformidad con el funcionamiento de los servicios públicos.

- **Agencia Estatal de Evaluación de Políticas Públicas y de la Calidad de los Servicios**, desarrolla una actividad institucional en la que se une la voluntad de mejorar la calidad de los servicios públicos con la de racionalizar el uso de los recursos públicos y rendir cuentas ante los ciudadanos. La Agencia es un organismo público regulado en la Ley 28/2006, de 18 de julio, de Agencias estatales para la mejora de los servicios públicos. La Agencia tiene como propósito contribuir a: mejorar los servicios públicos y el conocimiento de los efectos en la sociedad de las políticas y programas públicos, promover una mayor racionalidad del gasto público y la optimización en el uso de los recursos, favorecer la productividad y competitividad de la economía española eliminando trabas burocráticas, aumentar la rendición de cuentas respecto a los ciudadanos y la calidad democrática, promoviendo la transparencia y la participación.

La evaluación de políticas públicas tiene antecedentes en numerosos países y actividades, en este sentido en España, se crea el **Observatorio de la Calidad de los Servicios públicos**, regulado por el Real Decreto 951/2005, que debe informar periódicamente del nivel de calidad con que se prestan los servicios públicos, presentando y difundiendo anualmente un informe de evaluación global de los servicios analizados.

- **Consejo Superior de Administración Electrónica**, creado por Real Decreto 589/2005 de 20 de mayo, es un órgano colegiado adscrito al Ministerio de Administraciones Públicas y encargado de la preparación, elaboración, desarrollo y aplicación de la política y estrategia del Gobierno en materia de tecnologías de la información, así como del impulso e implantación de la Administración electrónica en la Administración General del Estado (AGE).<sup>8</sup> Puede actuar en Pleno y en Comisión Permanente.

El Pleno es presidido por el Ministro de Administraciones Públicas y entre sus vocales se encuentran todos los Subsecretarios de los Ministerios.

Entre sus funciones destaca: el desarrollo de políticas y estrategias en materia de tecnologías de la información, la planificación y elaboración de directrices generales que sirvan de base a los planes estratégicos departamentales en materia de tecnologías de la información, asesoramiento y consultoría en materia presupuestaria, recursos humanos y organización de las tecnologías de la información, cooperación con las comunidades autónomas y entidades locales en la puesta en marcha de servicios públicos inter administrativos, así como con la Unión Europea y con organizaciones internacionales, funciones de seguridad en colaboración con el Centro Criptológico

---

<sup>8</sup> Real Decreto 1390/2012, de 5 de octubre, (Ministerio de Hacienda y Administraciones Públicas) por el que se modifica el Real Decreto 589/2005, de 20 de mayo, por el que se reestructuran los órganos colegiados responsables de la administración electrónica.

Nacional del Centro Nacional de Inteligencia, difundiendo medidas de seguridad de tecnologías de información, adquisición de material de cifra y formando especialistas en seguridad de los sistemas, organizando conferencias y otras actividades para el intercambio de experiencias, análisis y estudio de la situación de la administración electrónica, actuando como Observatorio de la Administración Electrónica.

Entre otras actividades de producción y difusión de estándares y recomendaciones (METRICA versión 3, SICRES, Guías técnicas aplicables a la contratación de bienes y servicios de tecnologías de la información y las comunicaciones) cabe citar los relacionados con la seguridad de los sistemas de la información: los **Criterios generales de seguridad, normalización y conservación de la aplicaciones cuyo resultado sea utilizado para el ejercicio de potestades**<sup>9</sup>, aprobados por Resolución de 28 de mayo de 2003, **MAGERIT** versión 3, se trata de una metodología de Análisis y Gestión de Riesgos de los sistemas de información, y su herramienta PILAR, procedimiento informático-lógico para el análisis y la gestión de los riesgos de un sistema de información; el consejo impulsa también el proyecto del Esquema Nacional de Evaluación y Certificación de la Seguridad de los Sistemas de Información a través de un Grupo ad hoc del Comité Técnico de Seguridad de los Sistemas de Información y Protección de datos (SSITAD). El Centro Criptológico Nacional tiene un notable protagonismo en este proyecto como organismo de certificación, según lo dispuesto en la Ley 11/2002 de 6 de mayo reguladora del Centro Nacional de Inteligencia y en el Real Decreto 421/2004 de 12 de mayo, por el que se regula el Centro Criptológico Nacional. Actualmente el CCN se ha encargado de la elaboración de las guías técnicas del Esquema Nacional de Seguridad donde la Guía 802 establece el marco de actuaciones en torno a la Auditoría de Seguridad.

- **La Agencia Española de Protección de Datos**, Ente de Derecho Público con personalidad jurídica propia y plena capacidad pública y privada. Actúa con independencia de las Administraciones Públicas en el ejercicio de sus funciones. Velar por el cumplimiento de la legislación sobre protección de datos y controlar su aplicación, en especial en lo relativo a los derechos de información, acceso, rectificación, oposición y cancelación de datos. El marco jurídico de referencia es:
  - Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal (Título VI con rango de ley ordinaria).
  - Real Decreto 1720/2007 por el que se aprueba el Reglamento de desarrollo de la Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal.
  - Real Decreto 428/1993, de 26 de marzo, por el que se aprueba el Estatuto de la Agencia Española de Protección de Datos.

Para resumir, podemos concluir que en la Administración se desarrollan funciones de auditoría de sistemas de información, según hemos analizado en este apartado, en dos modelos principales (si el departamento de auditoría interna forma parte de los órganos de control o si forma parte de los propios centros informáticos).

Debe tenerse presente que, según el tamaño de la organización, la función de auditoría informática no necesariamente recaerá en una unidad específica, sino que podrá ser una especialización dentro de una unidad con más alcance, como pueden ser las Inspecciones de los Servicios en la Administración General del Estado (AGE). En el caso concreto de la

---

<sup>9</sup> Actualmente no están vigentes, el marco de referencia serían las leyes 39/2015 y 40/2015 y los Esquemas Nacionales de Seguridad y de Interoperabilidad. Se referencian por ser uno de los primeros intentos en establecer un marco de referencia en cuanto a la seguridad e interoperabilidad en España.

Administración Pública que presta servicios electrónicos a los ciudadanos, se requiere el establecimiento de medidas tanto técnicas como organizativas, que aseguren el mantenimiento de las garantías en los procedimientos y fortalezcan la confianza de los usuarios y administrados. El auditor informático debe colaborar, para ello debe comprender los procesos de los servicios públicos, evaluar programas y políticas públicas para la mejora de la calidad de los servicios (con referencia a los modelos EFQM y EVAM), evaluar cartas de servicios, analizar la demanda de los usuarios, evaluar la satisfacción de los usuarios, etc.

### **36.01.06 Guía de Auditoría del Esquema Nacional de Seguridad**

La Guía de auditoría del Esquema Nacional de Seguridad se encuadra dentro de lo previsto en el artículo 42 de la Ley 11/2007, de 22 de junio, de acceso electrónico de los ciudadanos a los Servicios Públicos (ya derogada), y específicamente dentro de los requisitos del artículo 34 (Auditoría de la seguridad), y del Anexo III (Auditoría de la Seguridad) del Real Decreto 3/2010 de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica (RD 3/2010 en adelante).

El Anexo III (Auditoría de Seguridad) establece en su apartado 1. Objeto de la auditoría:

1. La seguridad de los sistemas de información de una organización será auditada en los siguientes términos:

- a. Que la política de seguridad define los roles y funciones de los responsables de la información, los servicios, los activos y la seguridad del sistema de información.
- b. Que existen procedimientos para resolución de conflictos entre dichos responsables.
- c. Que se han designado personas para dichos roles a la luz del principio de «separación de funciones».
- d. Que se ha realizado un análisis de riesgos, con revisión y aprobación anual.
- e. Que se cumplen las recomendaciones de protección descritas en el anexo II, sobre Medidas de Seguridad, en función de las condiciones de aplicación en cada caso.
- f. Que existe un sistema de gestión de la seguridad de la información, documentado y con un proceso regular de aprobación por la dirección.

En lo relativo a los Niveles de Auditoría (apartado 2):

Los niveles de auditoría que se realizan a los sistemas de información serán los siguientes:

#### **1. Auditoría a sistemas de categoría BÁSICA.**

Los sistemas de información de categoría BÁSICA, o inferior, no necesitarán realizar una auditoría. Bastará una autoevaluación realizada por el mismo personal que administra el sistema de información, o en quien éste delegue.

- a) El resultado de la autoevaluación debe estar documentado, indicando si cada medida de seguridad está implantada y sujeta a revisión regular y las evidencias que sustentan la valoración anterior.
- b) Los informes de autoevaluación serán analizados por el responsable de seguridad competente, que elevará las conclusiones al responsable del sistema para que adopte las medidas correctoras adecuadas.

#### **2. Auditoría a sistemas de categoría MEDIA O ALTA.**

- a) El informe de auditoría dictaminará sobre el grado de cumplimiento del presente real decreto, identificará sus deficiencias y sugerirá las posibles medidas correctoras o complementarias que sean necesarias, así como las recomendaciones que se consideren oportunas. Deberá, igualmente, incluir los criterios metodológicos de auditoría utilizados, el alcance y el objetivo de la

auditoría, y los datos, hechos y observaciones en que se basen en que se basen las conclusiones formuladas.

- b) Los informes de auditoría serán analizados por el responsable de seguridad competente, que presentará sus conclusiones al responsable del sistema para que adopte las medidas correctoras adecuadas.

La interpretación de lo recogido durante la ejecución de la auditoría se realizará según el sentido propio de sus palabras, en relación con el contexto, antecedentes históricos y legislativos, entre los que figura lo dispuesto en la instrucción técnica CCN-STIC correspondiente (Guía 802 Auditoría de Seguridad).

Tal y como recoge la propia guía, su objetivo es establecer una forma homogénea la realización de las auditorías, definiendo unos requisitos mínimos para llevarlas a cabo, y permitiendo el trabajo de los auditores <sup>10</sup> sin problemas a la hora de emitir una opinión objetiva e independiente en el informe de auditoría, siempre que se desarrolle dentro de los objetivos y alcances requeridos por el artículo 34.

La emisión de esa opinión independiente y objetiva sobre el cumplimiento del Esquema Nacional de Seguridad, permitirá a los responsables correspondientes, tomar las medidas oportunas para subsanar las deficiencias identificadas, si las hubiera, y para satisfacerse internamente, o bien frente a terceros que pudieran estar relacionados, sobre el nivel de seguridad implantado.

**Esta auditoría es requerida, de forma ordinaria, cada dos años para los sistemas de categoría media y alta, según el Anexo I del RD 3/2010, y con carácter extraordinario, siempre que se produzcan modificaciones sustanciales en el sistema de información, que puedan repercutir en las medidas de seguridad requeridas.** La realización de la auditoría extraordinaria determinará la fecha de cómputo para el cálculo de los dos años, establecidos para la realización de la siguiente auditoría regular ordinaria.

Se establece que "En el caso de los sistemas de categoría ALTA, visto el dictamen de auditoría, el responsable del sistema podrá acordar la retirada de operación de alguna información, de algún servicio o del sistema en su totalidad, durante el tiempo que estime prudente y hasta la satisfacción de las modificaciones prescritas".

**El objetivo final de la auditoría es sustentar la confianza que merece el sistema auditado en materia de seguridad; es decir, calibrar su capacidad para garantizar la integridad, disponibilidad, autenticidad, confidencialidad y trazabilidad de los servicios prestados y la información tratada, almacenada o transmitida.**

La estructura de la Guía es:

---

<sup>10</sup> El equipo auditor deberá estar compuesto por un equipo de profesionales (jefe del equipo de auditoría, auditores, y expertos) que garantice que se dispone de los conocimientos (de acuerdo con el alcance establecido para la auditoría) suficientes para asegurar la adecuada y ajustada realización de la auditoría. En el Anexo A de la Guía se establecen unos requisitos mínimos para los integrantes del equipo de auditoría.

**ÍNDICE**

|                                                                                             |           |
|---------------------------------------------------------------------------------------------|-----------|
| <b>1. MARCO DE REFERENCIA.....</b>                                                          | <b>4</b>  |
| <b>2. OBJETO DE LA AUDITORÍA.....</b>                                                       | <b>5</b>  |
| <b>3. DESARROLLO Y EJECUCIÓN DE LA AUDITORÍA.....</b>                                       | <b>5</b>  |
| 3.1. DEFINICIÓN DEL ALCANCE Y OBJETIVO DE LA AUDITORÍA.....                                 | 6         |
| 3.2. EQUIPO AUDITOR.....                                                                    | 7         |
| 3.3. PLANIFICACIÓN PRELIMINAR DE LA AUDITORÍA.....                                          | 8         |
| 3.4. PROGRAMA DE AUDITORÍA.....                                                             | 10        |
| 3.5. REVISIONES Y PRUEBAS DE AUDITORÍA.....                                                 | 13        |
| 3.6. ELABORACIÓN Y PRESENTACIÓN DE LOS RESULTADOS DE REVISIONES Y PRUEBAS DE AUDITORÍA..... | 15        |
| 3.7. PRESENTACIÓN DEL INFORME DE AUDITORÍA.....                                             | 15        |
| <b>ANEXO A. REQUISITOS PARA EL EQUIPO AUDITOR.....</b>                                      | <b>18</b> |
| <b>ANEXO B. INCORPORACIÓN DE EXPERTOS AL EQUIPO DE AUDITORÍA.....</b>                       | <b>19</b> |
| <b>ANEXO C. CONCURRENCIA CON EL TÍTULO VIII DEL RD 1720/2007.....</b>                       | <b>20</b> |
| <b>ANEXO D. MODELO DE ACUERDO DE CONFIDENCIALIDAD.....</b>                                  | <b>22</b> |
| <b>ANEXO E. GLOSARIO DE TERMINOS.....</b>                                                   | <b>24</b> |
| <b>ANEXO F. BIBLIOGRAFÍA DE REFERENCIA.....</b>                                             | <b>29</b> |

11

Por destacar alguno de los aspectos más relevantes de la Guía, el desarrollo de auditoría tiene que permitir definir:

- El Alcance y Objetivo de la Auditoría.
- Los recursos necesarios y apropiados para realizar la auditoría (equipo auditor).
- Las debidas comunicaciones con los responsables de la organización que soliciten la auditoría.
- La planificación preliminar o requisitos de información previos al desarrollo del programa de auditoría, y a la ejecución de las pruebas que se consideren necesarias.
- El establecimiento de un programa detallado de auditoría con las revisiones y pruebas de auditoría previstas.
- La presentación, de los resultados individuales de las pruebas, a las personas involucradas con estos resultados, para su confirmación sin valoraciones con respecto a los resultados finales.
- La evaluación global de los resultados de la auditoría en relación con el objetivo y alcance definidos y a los requisitos del RD 3/2010.
- La confección, presentación y emisión formal del Informe de Auditoría.

Entre las medidas de seguridad a analizar durante la ejecución de la auditoría:

- Verificar la existencia de la Política de Seguridad.
- Valorar la información y los servicios, junto con la determinación de la categoría del sistema.

<sup>11</sup> <https://www.ccn-cert.cni.es/publico/seriesCCN-STIC/series/800->

Esquema\_Nacional\_de\_Seguridad/802-Auditoria\_ENS/802-Auditoria\_ENS-jun10.pdf

- Verificar la existencia de la Política de Firma Electrónica y Certificados y servicios que utilizan estas técnicas.
- Recopilar la información, servicios y demás recursos sujetos a la auditoría.
- Analizar los tipos de datos que se manejan, así como la normativa que les sea de aplicación (ej. Datos de carácter personal).
- Verificar la existencia y nombramiento del órgano de las AAPP responsable y personal afectado por la auditoría.
- Identificar las conexiones externas con otros organismos públicos o privados.

Por último, en lo relativo al informe de auditoría, éste incluirá una opinión sobre si:

- La Política de Seguridad define los roles y funciones de los responsables de la información, los servicios, los activos y la seguridad del sistema de información.
- Existen procedimientos para la resolución de conflictos entre dichos responsables.
- Se han designado personas para dichos roles a la luz del principio de "separación de funciones".
- Existe un sistema de gestión de la seguridad de la información, documentado y con un proceso regular de aprobación por la dirección.
- Se ha realizado un análisis de riesgos, con revisión y aprobación regular, según lo establecido en las medidas aplicables del Anexo II del RD 3/2010.
- Se cumplen las medidas de seguridad descritas en el Anexo II, sobre Medidas de Seguridad, en función de las condiciones de aplicación en cada caso.
- Existe un sistema de gestión de mejora continua.
- Si la auditoría se realizara juntamente con la requerida por el RD 1720/2007 en sus artículos 96 y 110, es necesario que el informe indique con claridad cuando una deficiencia de seguridad o incumplimiento, o una mejora recomendada está, individualmente, relacionada con ambas normas, o bien con una en concreto.

### 36.02. Administración y planificación

Uno de los marcos de referencia más utilizados en auditoría informática es COBIT <sup>12</sup> ([www.isaca.org](http://www.isaca.org)), se trata de una institución americana, dependiente del IT Governance Institute que nació a finales de 1995, principios de 1996. Su misión y objetivos es investigar, desarrollar y promocionar objetivos de control relacionados con las Tecnologías de la Información a nivel internacional. COBIT se caracteriza por su orientación al negocio, recopila un juego internacional de objetivos de control actualizados que cuentan con amplia aceptación para su uso diario por parte de los encargados del negocio y de los encargados de Tecnologías de la Información. Recoge indicadores clave de rendimiento asociados a la mejora de procesos. Está diseñado para utilizarse además como lista de verificación (LV), o construir LV basadas en él; busca equilibrio entre 1) riesgos de negocio, 2) necesidades de control y 3) aspectos técnicos. Proporciona "prácticas saludables" a través de un Marco Referencial de dominios y procesos y presenta actividades en una estructura manejable y lógica.

Otro referente claro es ITIL. Originalmente creado por el gobierno del Reino Unido, ITIL resume las mejores prácticas de implementación en la gestión de los procesos de Tecnologías de la Información. Define los procesos para desplegar y mantener servicios de TI (asimilables normalmente a aplicaciones) centrando su foco en el negocio. La filosofía ITIL gira alrededor de la gestión de incidencias como plataforma de comunicación y de una base de datos que centraliza la de gestión de la configuración (CMDB).

En un vistazo general parece que COBIT se solapa considerablemente con ITIL, sin embargo COBIT tiene una clara influencia por el área de seguridad: fusiones y adquisiciones, subcontratación, auditoría, son capítulos clave en el marco de referencia COBIT.

---

<sup>12</sup> La versión vigente a enero de 2013 es la versión 5 de CobiT.

Ambos marcos de trabajo se son de aplicación a las áreas de TI, y por destacar la diferencia entre ambas:

- CobiT → Pretende establecer los procesos de IT de modo que estén perfectamente alineados con los objetivos de Negocio. Los controles del modelo buscan en todo momento garantizar que los recursos IT son los necesarios para que la organización consiga sus objetivos empresariales.
- ITIL → Se centra más en la prestación de servicios de IT en un contexto de un acuerdo empresarial donde el cumplimiento de los ANS (acuerdos de los niveles de servicio) marcan la actuación del área de IT.

### **36.02.01 Proceso de una auditoría**

Corresponde a la alta dirección de la organización soportar el mantenimiento de la función de auditoría de sistemas de información para el control de los recursos propios. Para ello, además de la estructura organizativa, deben definirse previamente el marco de las actividades que se llevarán a cabo en las auditorías informáticas, que deben materializarse en un escrito que se denomina **mandato de la función de auditoría interna**. Interesa indicar también las excepciones, lo que NO se va a auditar.<sup>13</sup>

Si se requiere contar con apoyo externo se realizará un contrato de servicios que materializará el **mandato para la auditoría externa**, siempre será éste la norma que regulará el proceso de auditoría.

### **36.02.02 Estándares y normas técnicas**

Los instrumentos de normalización y estándares son amplios y variados, en función del sector a auditar, algunos de ellos son:

#### **. NORMAS DEL SECTOR PÚBLICO:**

- Normas de Auditoría del Sector Público de la IGAE, que, aunque no son específicas para la auditoría informática establecen un marco organizativo ([www.igae.pap.minhap.gob.es](http://www.igae.pap.minhap.gob.es)).
- Resolución de 23 de junio de 2003, del Instituto de Contabilidad y Auditoría de Cuentas, por la que se publica la norma técnica de auditoría sobre "la auditoría de cuentas en entornos informatizados".
- Serie del Centro Criptográfico Nacional "Seguridad de las Tecnologías de la Información" (consultar CCN-STIC en [www.ccn-cert.cni.es](http://www.ccn-cert.cni.es)), entre las que destacan:

---

<sup>13</sup> Como referencia la implantación de una norma como la ISO 9001 exige como uno de los procedimientos principales de la organización el de Auditorías internas.

| Series CCN-STIC |                                          |
|-----------------|------------------------------------------|
|                 | Indice de Guías CCN-STIC                 |
| ⊕               | Guías de acceso público                  |
| ⊕               | Serie 000: Políticas                     |
| ⊕               | Serie 100: Procedimientos                |
| ⊕               | Serie 200: Normas                        |
| ⊕               | Serie 300: Instrucciones técnicas        |
| ⊕               | Serie 400: Guías generales               |
| ⊕               | Serie 500: Guías de entornos Windows     |
| ⊕               | Serie 600: Guías de otros entornos       |
| ⊕               | Serie 800: Esquema Nacional de Seguridad |
| ⊕               | Serie 900: Informes técnicos             |

<https://www.ccn-cert.cni.es/>

- Serie 000 Políticas: CCN-STIC-001 Seguridad de las TIC en la Administración.
  - Serie 100 Procedimientos: CCN-STIC-101 Procedimiento de Acreditación Nacional.
  - Serie 200 Normas: CCN-STIC-201 Estructura de Seguridad.
  - Serie 300 Instrucciones Técnicas: CCN-STIC-301 Requisitos STIC.
  - Serie 400 Guías Generales: CCN-STIC-402 Organización y Gestión TIC, CCN-STIC-406 Seguridad Wireless, CCN-STIC-408 Seguridad Perimetral – Cortafuegos, CCNSTIC-430 Herramientas de Seguridad.
  - Serie 500 Guías para Entornos Windows: CCN-STIC-503 Seguridad en Windows 2003 Server, CCN-STIC-504 Seguridad en Internet Information Server.
  - Serie 600: Guías para Otros Entornos: CCN-STIC-601 Seguridad HP-UX, CCNSTIC-611 Seguridad SUSE Linux, CCN-STIC-621 Seguridad Sun-Solaris.
  - Serie 800: Guías de desarrollo del Esquema Nacional de Seguridad donde destacaría la 802 de Auditoría de Seguridad.
- Information Technology Infrastructure Library (ITIL) desarrollada por Office of Government Commerce del H.M.Treasury de UK Government, constituye una guía de las mejores prácticas para la gestión de servicios de tecnologías de la información (disponible en [www.ogc.gov.uk](http://www.ogc.gov.uk)).
  - Publicaciones Especiales del Instituto Nacional de Estándares y Tecnología de EE.UU. (NIST Special Publications disponibles en [csrc.nist.gov/publications/nistpubs/index.html](http://csrc.nist.gov/publications/nistpubs/index.html)), entre las que destacan:
    - SP-800-14 Generally Accepted Principles and Practices for Securing Information Technology Systems
    - SP-800-18 Guide for Developing Security Plans for Information Technology
    - SP-800-26 Security Self-Assessment Guide for Information Technology Systems
    - SP-800-34 Contingency Planning for IT Systems
    - SP-800-53 Recommended Security Controls for Federal Information Systems

- SP-800-55 Security Metrics Guide for Information Technology Systems
- SP-800-61 Computer Incident Handling Guide
- SP-800-64 Security Considerations in the Information System Development Life Cycle.

#### **. RECOMENDACIONES DE ORGANIZACIONES INTERNACIONALES:**

- Control Objectives for Information and Related Technologies (COBIT) de la Asociación de Auditoría y Control de Sistemas de Información (ISACA), establecen un marco para la auditoría informática y son un referente empleado por muchas organizaciones (disponible en <http://www.isaca.org/Template.cfm?Section=COBIT6&Template=/TaggedPage/TaggedPageDisplay.cfm&TPLID=55&ContentID=7981>).
- IS Standards, Guidelines and Procedures for Auditing and Control Professionals de ISACA, define los procedimientos a realizar en determinadas actuaciones de auditoría informática e incluye su código de ética profesional (disponible en [www.isaca.org](http://www.isaca.org)).
- Instituto SANS (SysAdmin, Audit, Network, Security), publica varios programas (disponibles en [www.sans.org](http://www.sans.org)), entre los que destacan:
  - SANS Security Policy Project: plantillas con distintas políticas de seguridad.
  - SANS SCORE (Security Consensus Operational Readiness Evaluation): mejores prácticas y mínimos requerimientos de seguridad para diversos sistemas y software base.
  - SANS/FBI Top20 Vulnerabilities List.

#### **. NORMAS INTERNACIONALES:**

- Código de buenas prácticas para la gestión de la seguridad de la información, actual ISO/IEC 27002.
- Especificaciones para los sistemas de gestión de la seguridad de la información (SGSI) ISO/IEC 27001:2005.
- Criterios comunes de evaluación de la seguridad de las tecnologías de la información ISO/IEC 15408:2005 (Common Criteria for Information Technology Security Evaluation Versión 2.3 Agosto 2005, disponible en [http://www.oc.ccn.cni.es/ccv2.3\\_es.html](http://www.oc.ccn.cni.es/ccv2.3_es.html)), desarrollados por los organismos de normalización CSE - Canadá, SCS - Francia, BSI - Alemania, NLNCSA - Holanda, CESG - Reino Unido, NIST - EE.UU. y NSA - EE.UU.), y que comprende los siguientes documentos:
  - ISO/IEC 15408-1:2005 Part 1 – Introduction and general model.
  - ISO/IEC 15408-2:2005 Part 2 – Security functional requirements.
  - ISO/IEC 15408-3:2005 Part 3 – Security assurance requirements.
- Gestión de la seguridad de las tecnologías de la información y las comunicaciones ISO/IEC 13335:2004, y que comprende los siguientes documentos:
  - ISO/IEC 13335-1:2004 Part 1 – Concepts and models for information and communications technology security management.
  - ISO/IEC 13335-2 (en desarrollo) Part 2 – Information security risk management o ISO/IEC 13335-3:1998 Part 3 – Techniques for the management of IT security
  - ISO/IEC 13335-4:2000 Part 4 – Selection of safeguards
  - ISO/IEC 13335-5:2001 Part 5 – Management guidance on network security.
- Metodología para la evaluación de la seguridad de los sistemas de información ISO/IEC 18045:2005.

. **PROCEDIMIENTO ADMINISTRATIVO:** Ya comentado en el apartado 31.3.01.03, todo ello disponible en el Portal de la Administración electrónica (PAe → [administracionelectronica.gob.es](http://administracionelectronica.gob.es))

- La Ley 11/2007, de 22 de junio, de Acceso Electrónico de los Ciudadanos a los Servicios Públicos.
  - Real Decreto 1671/2009, de 6 de noviembre, por el que se desarrolla parcialmente la Ley 11/2007, de 22 de junio, de acceso electrónico de los ciudadanos a los servicios públicos.
  - Real Decreto 4/2010, de 8 de enero (BOE de 28 de enero), por el que se regula el Esquema Nacional de Interoperabilidad en el ámbito de la administración electrónica.
  - Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica.
- MAGERIT Versión 3, Metodología de análisis y gestión de riesgos de los sistemas de información.

#### . **PROTECCION DE DATOS DE CARÁCTER PERSONAL:**

Merece la pena consultar el portal de la Agencia Española de Protección de Datos en lo relativo no sólo a la normativa de referencia, sino a las recomendaciones, informes y resoluciones de la Agencia ([www.agpd.es](http://www.agpd.es)).

- Ley Orgánica 15/1999, de protección datos de carácter personal (publicada en el BOE de 14/12/1999).
  - Real Decreto 1720/2007, de 21 de diciembre, por el que se aprueba el Reglamento de desarrollo de la Ley Orgánica 15/1999, de 13 de diciembre, de protección de datos de carácter personal.

### **36.02.03 Planificación**

La planificación consiste en la fijación de objetivos y metas, así como en la propuesta de estrategias, políticas y programas tendentes a alcanzarlos. **Las actuaciones de Auditoría Informática requieren una planificación en tres niveles.**

**En el primero** de ellos se define qué se debe auditar, estipulando las prioridades. Las acciones por emprender serán consecuencia de:

- Requerimientos legales (en este nivel de planificación, los estándares y las normas técnicas también se pueden emplear como referente del marco de control a supervisar).
- La sensibilidad de la organización a determinados riesgos o vulnerabilidades que puedan poner en peligro la confianza de los administrados (el resultado de un análisis de riesgos).
- El resultado de auditorías anteriores.

**En el segundo nivel** se decide cuándo auditar, priorizando las actuaciones a realizar, y ajustando el alcance de las mismas a los recursos disponibles.

Por último, en **el tercer nivel** se estipula el detalle de cómo realizar las actuaciones previstas en ese plan, que se materializarán en actuaciones concretas. Como paso previo a cualquier actuación de campo, el equipo de auditoría designado deberá definir los trabajos a realizar para poder establecer los objetivos perseguidos.

Debe obtenerse toda la información preliminar sobre la actividad llevada a cabo por el área sujeta a la actuación de auditoría, en especial el esquema organizativo de control interno,

contra el cual se efectuará la evaluación: políticas, normas, procedimientos e instrucciones técnicas aplicables al alcance de la actuación.

Tal y como recoge la Guía 802, que establece unos requisitos mínimos, no limita las metodologías o procesos que seguir, es decir se podrán emplear como referencia estándares de organizaciones internacionales (ISO, Instituto Sans, etc.), o conjuntos de buenas prácticas de organismos de reconocido prestigio (COBIT, NIST, Serie CCN-STIC del CNI, etc.), siempre que cumpla los citados requisitos.

Si el área en cuestión ha sido auditada con anterioridad, debe revisarse la documentación previa para familiarizarse con las operaciones llevadas a cabo, y deberán identificarse y revisarse todos los cambios realizados desde entonces.

Con toda la información el equipo auditor podrá definir los objetivos detallados de la actuación, realizar un calendario tentativo, identificar los interlocutores, establecer el tipo de información a recopilar y las verificaciones o pruebas de campo a efectuar durante la actuación. En definitiva, estructurar los contenidos en un Guion de la Actuación que se empleará para sistematizar las tareas. En el apartado 03.04.01 se analizan en detalle el proceso de planificación de la auditoría, describiendo en cada una de sus fases.

#### **36.02.04 Auditoría asistida por ordenador y software de auditoría informatizada (CAAT)**

Existen herramientas, en general productos informáticos, que facilitan la generación de muestras, se emplean para interrogar a los sistemas de información o para extraer información que luego será tratada por otra herramienta de análisis.

El empleo de herramientas asegura independencia en el proceso de recolección de los datos, y suelen tener las siguientes características:

- Acceso a distintas estructuras o formato de datos;
- reorganización de archivos, incluyendo indexación, clasificación fusión y cruce;
- selección de datos, filtrado y aplicación de criterios de búsqueda;
- funciones estadísticas (muestreo, estratificación y frecuencias);
- funciones aritméticas.

Las técnicas de auditoría asistidas por computadora son de suma importancia para el auditor de TI cuando realiza una auditoría. CAAT incluyen distintos tipos de herramientas y de técnicas, las que más se utilizan son el software de auditoría generalizado, software utilitario, los datos de prueba y sistemas expertos de auditoría. Las CAAT se pueden utilizar para realizar varios procedimientos de auditoría incluyendo:

- Prueba de los detalles de operaciones y saldos.
- Procedimientos de revisión analíticos.
- Pruebas de cumplimiento de los controles generales de sistemas de información.
- Pruebas de cumplimiento de los controles de aplicación.

Estos productos pueden realizar las siguientes funciones:

- Metodologías de análisis de riesgos, permiten personalizar los criterios de riesgo para cada organización,
- Planificación de auditorías,

- Generación y gestión de los papeles de trabajo,
- Generación de informes,
- Procedimientos de tramitación de los informes,
- Obtención de copias para archivo,
- Estadísticas de las actuaciones,
- Administración y gestión de la seguridad del producto.

Suelen incorporar además las técnicas más sofisticadas de análisis de ficheros y extracción de datos, con objeto de detectar la manipulación o fraude y permitir el seguimiento continuo de los procesos de las organizaciones.

- Cuentan con herramientas como:
- Cuestionario general inicial. Cuestionarios Checklist.
- Estándares. Monitores.
- Simuladores (Generadores de datos).
- Paquetes de auditoría (Generadores de Programas).

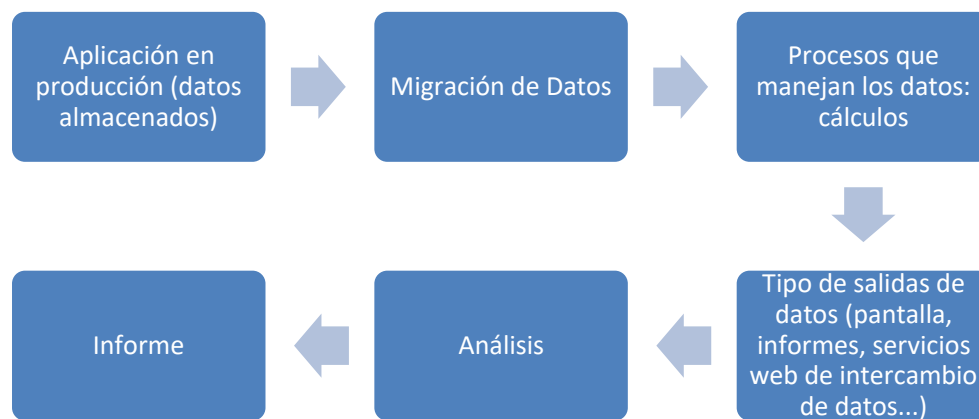
No siempre serán productos específicos, ya que las herramientas o utilidades de los sistemas operativos o de los sistemas gestores de bases de datos pueden emplearse para estos fines, dado que recogen datos de los controles efectivamente implementados en los registros de eventos (logs). Las **ventajas** del uso de herramientas de auditoría informática son: disminución del riesgo propio del proceso de auditoría en la recolección de datos; mayor independencia; mayor cobertura y más consistentes al poder emplear un alto número de datos, analizando más y mayores muestras; mayor disponibilidad; ahorro de costes con el tiempo.

La norma **SAP 1009 (Statement of Auditing Practice)** denominada Computer Assisted Audit Techniques (CAATs) o Técnicas de Auditoría Asistidas por Computador, plantea la importancia del uso de CAAT en auditorías en un entorno de sistemas de información por computadora. SAP 1009 los define como programas de computadora y datos que el auditor usa como parte de los procedimientos de auditoría para procesar datos de significancia en un sistema de información.

SAP 1009 describe los procedimientos de auditoría en que pueden ser usados los CAAT:

1. Pruebas de detalles de transacciones y balances (recálculos de intereses, extracción de ventas por encima de cierto valor, etc.)
2. Procedimientos analíticos, por ejemplo identificación de inconsistencias o fluctuaciones significativas.
3. Pruebas de controles generales, tales como configuraciones en sistemas operativos, procedimientos de acceso al sistema, comparación de códigos y versiones.
4. Programas de muestreo para extraer datos.
5. Pruebas de control en aplicaciones.
6. Recálculos.

Según SAP1009 un posible flujo de un CAAT sería:



El software de auditoría consiste en aplicaciones utilizadas por el auditor, como parte de sus procedimientos de auditoría, para procesar datos relevantes en el proceso de auditoría de un sistema informático en la organización. Puede consistir en programas de paquete, programas escritos para un propósito, programas de utilería o programas de administración del sistema. Independientemente de la fuente de los programas, el auditor deberá verificar su validez para fines de auditoría antes de su uso.

**Técnicas para analizar programas:** Existen diferentes técnicas para analizar programas las cuales ayudan al auditor en el trabajo de campo y de las cuales las más importantes se mencionan a continuación:

- **Traceo:** Indica por donde paso el programa cada vez que se ejecuta una instrucción. Imprime o muestra en la pantalla el valor de las variables, en una porción o en todo el programa.
- **Mapeo:** Característica del programa tales como tamaño en bytes, localización en memoria, fecha de última modificación, etc.
- **Comparación de código:** Involucra los códigos fuentes y códigos objetos.
- **Job Accounting Software.** Informe de Contabilidad del Sistema: Utilitario del sistema operativo que provee el medio para acumular y registrar la información necesaria para facturar a los usuarios y evaluar el uso del sistema.

A la hora de llevar a cabo una auditoría considerando herramientas CAAT la planificación de la misma conlleva la selección de dicha herramienta, así como los pasos que se deben tomar en cuenta para la planificación y selección de la misma.

Cuando se planifica la auditoría, el auditor de sistemas de información debe considerar una combinación apropiada de las técnicas manuales y las técnicas de auditoría asistidas por computadora. Cuando se determina utilizar CAAT los factores a considerar son los siguientes:

- Conocimientos y experiencia del auditor en sistemas informáticos.
- Disponibilidad de los CAAT y de los sistemas de información.
- Eficiencia y efectividad de utilizar los CAAT en lugar de las técnicas manuales.
- Restricciones de tiempo.

Los pasos más importantes que el auditor de sistemas de información debe considerar cuando prepara la aplicación de los CAAT seleccionados son los siguientes:

- Establecer los objetivos de auditoría de los CAAT: Determinar accesibilidad y disponibilidad de los sistemas de información, los programas/sistemas y datos de la organización.
- Definir los procedimientos a seguir (por ejemplo: una muestra estadística, recálculo, confirmación, etc.).
- Definir los requerimientos de output.
- Determinar los requerimientos de recursos.
- Documentar los costos y los beneficios esperados.
- Obtener acceso a las facilidades de los sistemas de información de la organización, sus programas/sistemas y sus datos.
- Documentar los CAAT a utilizar incluyendo los objetivos, flujogramas de alto nivel y las instrucciones a ejecutar.
- Acuerdo con el cliente (auditado): Los archivos de datos, tanto como los archivos de operación detallados (transaccionales, por ejemplo), a menudo son guardados sólo por un período corto, por lo tanto, el auditor de sistemas de información debe arreglar que estos archivos sean guardados por el marco de tiempo de la auditoría.
- Organizar el acceso a los sistemas de información de la organización, programas/sistemas y datos con anticipación para minimizar el efecto en el ambiente productivo de la organización.

El **software de auditoría generalizado**, también conocidos como paquetes de auditorías en programas diseñados para desempeñar funciones de procesamiento de datos que incluyen leer archivos de computadora, seleccionar información, realizar cálculos, crear archivos de datos e imprimir informes en un formato especificado por el auditor.

Cuando un auditor de sistemas de información utiliza el software de auditoría generalizado para acceder a los datos de producción, se deben tomar las medidas apropiadas para proteger la integridad de los datos de la organización. Además, el auditor tiene que conocer el diseño del sistema y las técnicas que se utilizaron para el desarrollo y mantenimiento de los programas/sistemas de aplicación de la organización.

El **software utilitario** es utilizado para desempeñar funciones comunes de procesamiento de datos, como clasificación, creación e impresión de archivos. Estos programas generalmente no están diseñados para propósitos de auditoría y, por lo tanto, pueden no contener características tales como conteo automático de registros o totales de control.

Cuando el auditor utiliza el software utilitario debe confirmar que no tuvieron lugar ninguna intervención no planificada durante el procesamiento y que este software ha sido obtenido desde la biblioteca de sistema apropiado, mediante una revisión del log de la consola del sistema o de la información de contabilidad del sistema. El auditor tiene que tomar las medidas apropiadas para proteger la integridad del sistema y programas de la organización, puesto que estos utilitarios podrían fácilmente dañar el sistema y sus archivos.

Al final, el proceso de auditoría ha de proporcionar un informe que recoja los trabajos realizados, por este motivo el seguimiento y las conclusiones acerca de los resultados de los CAAT deben estar registradas en los papeles de trabajo de la auditoría. Las conclusiones acerca del funcionamiento del sistema de información y de la confiabilidad de los datos también deben estar registradas en los papeles de trabajo de la auditoría. El proceso paso a paso de los CAAT debe estar documentado adecuadamente para permitir que el proceso se mantenga y se repita por otro auditor de sistemas de información. Específicamente los papeles de trabajo deben

contener la documentación suficiente para describir la aplicación de los CAAT incluyendo los detalles que se mencionan en los párrafos siguientes:

- Planificación
- Los objetivos de los CAAT
- Los CAAT a utilizar
- Los controles a implementar
- El personal involucrado, el tiempo que tomará y los costos.

La documentación debe incluir:

- Los procedimientos de la preparación y la prueba de los CAAT y los controles relacionados.
- Los detalles de las pruebas realizadas por los CAAT.
- Los detalles de los inputs (ejemplo: los datos utilizados, esquema de archivos), el procesamiento (ejemplo: los flujogramas de alto nivel de los CAAT, la lógica).
- Evidencia de auditoría: el output producido (ejemplo: archivos log, reportes).
- Resultado de la auditoría.
- Conclusiones de la auditoría.
- Las recomendaciones de la auditoría.

En el informe de auditoría se deben describir brevemente las herramientas CAAT utilizadas si se ha dado el caso, mencionando los hallazgos específicos relacionados con el uso de los CAAT. Si se puede aplicar la descripción de los CAAT a varios hallazgos o si es demasiado detallado debe ser descrito brevemente en la sección del informe donde se tratan los objetivos, extensión y metodología y una referencia anexa para el lector, con una descripción más detallada.

Existen productos de software, suelen denominarse CAATT y que permiten realizar auditorías informatizadas en varias plataformas.

Algunas herramientas CAAT son:

**IDEA** ([www.cynthus.com.mx](http://www.cynthus.com.mx)): IDEA es reconocido en todo el mundo, como un estándar en comparaciones con otras herramientas de análisis de datos, ofreciendo una combinación única en cuanto a poder de funcionalidad y facilidad de uso.

**ACL** ([www.acl.com](http://www.acl.com)): es una herramienta CAAT enfocada al acceso de datos, análisis y reportes para auditores y profesionales financieros.

**Auto Audit** ([www.audisis.com](http://www.audisis.com)): es un sistema completo para la automatización de la función de Auditoría, soportando todo el proceso y flujo de trabajo, desde la fase de planificación, pasando por el trabajo de campo, hasta la preparación del informe final.

**AuditMaster** ([www.pervasive.com](http://www.pervasive.com)): es una solución de supervisión de transacciones a nivel de base de datos. Este sistema controla e informa de toda la actividad que tiene lugar en una base de datos Pervasive.SQL. La tecnología de AuditMaster consiste en capturar las operaciones que se realizan en la base de datos y escribirlas en un archivo de registro.

**Delos** ([www.cynthus.com.mx](http://www.cynthus.com.mx)): es un sistema experto que posee conocimientos específicos en materia de auditoría, seguridad y control en tecnología de información.

Otros ejemplos serían: TICOM III, ICE, DATAMACS, PRO TEST, EDP Auditor...

### 36.03. Organización, infraestructura técnica

En casi todas las grandes empresas y organizaciones, los auditores internos se organizan en un Departamento de Auditoría Interna separado, dependiente de la alta dirección y que constituye un órgano especializado de control. El tamaño de este departamento depende del tipo de participación en el control interno que tenga atribuido el departamento dentro de la organización. En el caso de la Administración Tributaria, por ejemplo, se sugiere en documentos internacionales que debería contar con un 0,5 a 1 % del personal de la organización.

Las funciones desempeñadas por este departamento suelen ser: establecer, mantener y mejorar controles efectivos (evaluando su eficacia y eficiencia), contribuir al establecimiento, mantenimiento y mejora del sistema de gestión de riesgos, velar por el mantenimiento de la seguridad en la organización (sugiriendo mejoras aplicables a la seguridad de los activos, y la seguridad física y lógica), pueden dedicarse también a cuestiones relativas a la regulación de normas de conducta del personal (promoción de valores éticos, prevención y detección de conductas irregulares...), y por último pueden ejercer como órgano de asesoría y consultoría al servicio de la dirección de la organización.

#### 36.03.01 Esquema Organizativo de la Función de Auditoría. Modelos Organizativos

- En un primer modelo, al igual que en los departamentos de auditoría interna de las organizaciones privadas, los auditores de sistemas de información **forman parte de los órganos de control**, supervisión o auditoría interna (intervenciones, inspecciones generales, servicios de auditoría, etc.).

Actúan: ejerciendo la supervisión del control interno y el análisis y gestión de riesgos en relación con los sistemas de información de la organización, realizando auditorías totales o parciales de los sistemas informáticos de la organización en la que se encuadran; participando, en su ámbito de especialización, en consultorías o asesoramiento a la organización en la que desarrollan sus actividades.

- El otro modelo incluye el trabajo de los auditores informáticos en **los propios centros informáticos**. En este caso, las actividades de auditoría se suelen concebir como un instrumento utilizado por los responsables directivos del centro para garantizar la seguridad y la calidad de las operaciones e identificar y mitigar los riesgos.

**La primera opción permite una mayor independencia del auditor al distanciarse en mayor medida del sujeto de su actuación.**

**La segunda opción ofrece una implicación más directa en las tareas destinadas a mejorar la calidad** y asegurar el funcionamiento de los sistemas de información, que se llevan a cabo en los propios Centros Informáticos.

En cualquier modelo organizativo elegido, han de cumplirse unos principios necesarios para que la función de auditoría pueda desarrollarse con éxito:

- **Independencia:** es esencial que no se asigne o encuadre dentro de un órgano que tenga asignadas funciones operativas. Asimismo, el personal designado para desempeñar las funciones de auditoría no debería participar en la preparación y desarrollo de procedimientos, o tomar decisiones ejecutivas que comprometieran su función en auditorías posteriores.
- **Autoridad:** los auditores deben tener acceso no restringido a la información, datos, informes, actividades y al personal de todas las unidades sujetas a auditar.

#### 36.03.02 El auditor informático. Perfil técnico. Ética profesional.

## Perfil técnico

En el ámbito del sector privado existen organizaciones profesionales que habilitan a un profesional como auditor informático mediante la certificación profesional que gestionan.

Una certificación profesional es un servicio de valor añadido cuya finalidad es generar confianza en la capacitación personal para ejercer profesionalmente para aquellos profesionales que satisfacen y acreditan un determinado nivel tanto de conocimientos como de experiencia.

En general, las áreas de conocimiento requeridas para cubrir el perfil profesional de un auditor pueden ser:

- Técnica o metodología de auditoría informática.
- Gestión, planificación y organización de las tecnologías de la información.
- Infraestructura técnica, prácticas operativas y protección de activos informáticos.
- Recuperación de desastres y continuidad de la actividad soportada por los sistemas de información.
- Desarrollo, adquisición, implementación y mantenimiento de sistemas de información.
- Evaluación de procesos de negocio y gestión de riesgos.

La certificación se obtiene después de aprobar un examen sobre esas materias, acreditar una experiencia profesional adecuada en el campo de las TIC y aceptar un código de ética profesional; y se mantiene acreditando una formación continua. En la siguiente figura se esquematiza la certificación profesional.

Existen diversas certificaciones profesionales en el ámbito de las tecnologías de la información, gestionadas en general por asociaciones profesionales, asociaciones industriales y por productores de hardware y software. Entre las más conocidas relativas a la auditoría de los sistemas de información, destacan las emitidas por la Asociación de Auditoría y Control de Sistemas de Información (Information Systems Audit and Control Association, ISACA):

### ISACA - Certificaciones

Si está trabajando en Auditoría, Seguridad o Gobierno de TI y quiere fortalecer su línea de carrera, gane reconocimiento como un experto en su profesión a través de las certificaciones de ISACA:

- CISA® (Certified Information Systems Auditor ®).
- CISM® (Certified Information Security Manager ®).
- CGEIT® (Certified In the Governance of Enterprises IT ®).
- CRISC® (Certified in Risk and Information Systems Control ®).

<http://www.isaca.org.pe/index.php/certificaciones.html>

Según el Anexo A de la Guía 802 los Requisitos para el equipo Auditor:

El Jefe del equipo de auditoría, responsable de gestionar las tareas de auditoría, deberá probar como mínimo:

- Acreditación de formación y experiencia en auditoría de sistemas de información, a través de certificaciones reconocidas a nivel nacional e internacional, o bien a través de experiencia verificable y evidenciada de al menos 4 años, en auditoría de tecnologías de la información.

- Conocimientos de seguridad y gestión de riesgos de seguridad (certificación y experiencia probada de al menos 4 años en estos elementos).
- Conocimiento de los requisitos del RD 3/2010.
- Conocimientos de otra legislación aplicable relativa a la protección de datos de carácter personal, y al acceso electrónico de los ciudadanos a los Servicios Públicos, y el RD 4/2010 de 8 de enero – Esquema Nacional de Interoperabilidad, entre otros.

El resto del equipo puede no cumplir con los requisitos para el Jefe del equipo de auditoría, no obstante debe tener alguna preparación previa tanto en seguridad como en auditoría de los sistemas de información, dependiendo de, y en consonancia, con las responsabilidades asignadas. La responsabilidad por la asignación de tareas al resto del equipo, incluyendo a los expertos, corresponde a la organización (privada o pública) que aporte el equipo de auditoría.

En cualquier caso, todos ellos han de haber firmado un acuerdo de confidencialidad para participar en la auditoría.

## Ética profesional

Además de los conocimientos y de la experiencia, o incluso de una certificación, es imprescindible el cumplimiento de un código de conducta en el ejercicio de la profesión, para asegurar la credibilidad del profesional.

Como ejemplo reproducimos el código de ética profesional definido por ISACA, de obligado cumplimiento para sus miembros y para los poseedores de sus certificaciones:

### ISACA - Código de Ética Profesional

ISACA establece este Código de Ética Profesional para guiar la conducta profesional y personal de los miembros de la asociación y/o de los portadores de las certificaciones.

Los miembros y los portadores de las certificaciones de ISACA deberán:

1. Apoyar la implementación de y alentar al cumplimiento de los estándares, procedimientos y controles apropiados para los sistemas de información.
2. Realizar sus funciones con objetividad, debida diligencia y celo profesional, de acuerdo con las normas y mejores prácticas profesionales.
3. Servir a los intereses de las partes relevantes de manera diligente, leal y honesta, manteniendo altos estándares de conducta y carácter, y no ser parte de ninguna actividad deshonrosa para la profesión.
4. Mantener la privacidad y confidencialidad de la información obtenida en el transcurso de sus funciones a menos que la autoridad legal requiera su divulgación. Dicha información no deberá ser usada para beneficio personal ni divulgada a las partes que no correspondan.
5. Mantener la competencia en sus respectivos campos y acordar realizar sólo aquellas actividades que de modo razonable puedan esperar cumplir con competencia profesional.
6. Informar a las partes apropiadas los resultados del trabajo realizado; revelando todos los hechos significativos de los que tengan conocimiento.
7. Apoyar la educación profesional de los interesados para mejorar su comprensión en seguridad y control de sistemas de información.

El incumplimiento de este Código de Ética Profesional puede resultar en una investigación de la conducta del miembro y/o del portador de la certificación y, finalmente, en medidas disciplinarias.

<http://www.isaca.org.pe/index.php/que-son-las-certificaciones/etica-profesional.html>

Para los profesionales de la Administración Pública no existe un código de estas características, pero como funcionarios están sujetos a mantener una conducta y diligencia profesional adecuada. A diferencia de un código de conducta, el Real Decreto 33/1986, de 10 de enero, aprueba el Reglamento de Régimen Disciplinario en la AGE en el que se estipulan las faltas, que cometidas por funcionarios en el ejercicio de sus cargos podrían suponer la aplicación de sanciones disciplinarias. Entre ellas se citan:

- Adopción de acuerdos manifiestamente ilegales que causen perjuicio a la Administración.
- No guardar el debido sigilo respecto a los asuntos que conozca por razón de su cargo.
- Descuido o negligencia en el ejercicio de sus funciones.
- Incumplimiento de sus deberes y obligaciones.

Los Subsecretarios de los Departamentos ministeriales son los que ostentan la competencia para ordenar la incoación del expediente disciplinario.

Con la publicación en la **Ley del Estatuto Básico del Empleado Público** (7/2007 de 12 de abril) de los deberes básicos de los empleados públicos, fundados en principios éticos y reglas de comportamiento, se constituye un auténtico código de conducta con unos principios éticos a los que los empleados públicos deberán ajustar sus actuaciones.

### 36.03. Prácticas operativas

El proceso de auditoría en su modelo más sencillo y tradicional constaría de tres fases: Planificación, Ejecución y Conclusiones.

En el contexto actual donde la mejora continua y el seguimiento se ha incorporado a cualquier proceso como una etapa fundamental, se va a analizar el desarrollo de una auditoría específica centrada en tecnologías de información. El proceso de trabajo se descompone en diferentes fases:

1. Planificación de la auditoría.
2. Ejecución de la auditoría propiamente dicha, se centra en el examen y evaluación de la información obtenida en la fase previa.
3. Comunicación de los resultados.
4. Seguimiento de las recomendaciones.



Se analizan en el apartado siguiente estas cuatro fases.

### **36.04.01 El proceso de la auditoría de sistemas de información (planificación de la actuación, formalización del inicio, trabajos de campo, evaluación de la información, comunicación de los resultados, seguimiento).**

#### **1. Planificación de una Auditoría**

Consiste en su preparación, se materializa en la elaboración de un **guion de auditoría o plan de trabajo** (meno denso que el guion) en el que se recogen los objetivos y el alcance de la auditoría, la metodología a seguir, y las actividades a desarrollar.

- Los **objetivos** de la auditoría definen lo que se pretende conseguir con la misma.
- El **alcance** define los límites del trabajo, es decir su ámbito de actuación funcional y territorial.
- Los **procedimientos** de auditoría son los métodos<sup>14</sup> aplicados para conseguir los objetivos de la auditoría y comprenden tanto los relativos al trabajo de recogida de información como los métodos que se usan en su análisis. Los auditores deben diseñar la metodología de forma que se obtengan pruebas que sustenten **evidencias o hallazgos** suficientes, relevantes y competentes para cumplir con los objetivos de la auditoría.

La fase de planificación se utiliza para obtener conocimientos generales y específicos sobre el órgano o actividad auditados, que permitan entender los hechos y prácticas realizadas en relación con los objetivos y alcance de la auditoría.

El trabajo de planificación concluye con la confección de un **plan de trabajo o guion de auditoría**. El guion incluye los siguientes apartados: identificación de los aspectos técnicos, riesgos, procesos y actuaciones que deben revisarse; naturaleza y extensión de las pruebas requeridas; definición de los procedimientos de auditoría que deben aplicarse para captar, analizar e interpretar la información; documentos e instrumentos que se van a utilizar en las actuaciones de auditoría, en particular las muestras que deben tomarse y la forma de obtenerlas; **cronograma** detallado de las actividades a realizar junto con el personal del equipo de auditoría asignado a cada tarea.

Según la Guía 802 la fase de planificación preliminar consiste en establecer los requisitos de información y documentación necesarias e imprescindibles para:

- Establecer y desarrollar el programa de auditoría.
- Concretar los conocimientos necesarios del equipo de auditoría.
- Definir la agenda de revisiones, reuniones y entrevistas.
- Definir las revisiones y pruebas a realizar.
- Adjudicar las tareas a los componentes del equipo de auditores y expertos.

---

<sup>14</sup> Método: "Conjunto de reglas ciertas y fáciles gracias a las cuales, quien la observe con exactitud, no tomará nunca lo falso por verdadero y llegará, sin realizar un esfuerzo inútil de la mente, sino aumentando siempre la ciencia de modo gradual, al verdadero conocimiento de todo aquello que sea capaz", Regulae ad Directionem Ingenii IV. René Descartes.

- Si se realiza una auditoría conjunta con la requerida por el RD 1720/2007, en sus artículos 96 y 110, identificar qué medidas de seguridad entran en el alcance de esta última. El objetivo de eficiencia es que la revisión de una misma medida sea auditada una sola vez, teniendo en cuenta los objetivos relacionados con el RD 3/2010, y con los del RD 1720/2007.

La documentación mínima que se requiere para concretar la planificación en detalle de la auditoría del cumplimiento del RD 3/2010, es:

- Documentos firmados por el órgano superior correspondiente, según se establece en el RD 3/2010, que muestren el conocimiento y la aprobación formal de las decisiones en materia de política de seguridad.
- Organigrama de los servicios o áreas afectadas, con descripción de funciones y responsabilidades.
- Identificación de los responsables: de la información, de los servicios, de la seguridad y del sistema, según se contemplan en el RD 3/2010.
- Descripción detallada del sistema de información a auditar (software, hardware, comunicaciones, equipamiento auxiliar, ubicaciones y similares).
- Identificación de la categoría del sistema según el Anexo I del RD 3/2010.
- Niveles de seguridad definidos.
- La Política de Seguridad.
- La Política de Firma Electrónica y Certificados (si se emplean estas tecnologías).
- La normativa de seguridad.
- Descripción detallada del sistema de gestión de la seguridad y la documentación que lo sustancia.
- Informes de análisis de riesgos.
- La Declaración de Aplicabilidad.
- Decisiones adoptadas para gestionar los riesgos.
- Relación de las medidas de seguridad implantadas.
- Relación de registros de actividad en lo relativo a las medidas de seguridad implantadas.
- Informes de otras auditorías previas de seguridad relacionados con los sistemas y servicios incluidos en el alcance de la auditoría, como podría ser, el informe de la auditoría bienal de protección de datos de carácter personal, o de auditorías previas con el mismo objetivo y alcance que la auditoría a comenzar.
- Informes de seguimiento de deficiencias detectadas en auditorías previas de seguridad, y relacionadas con el sistema a auditar.
- Lista de proveedores externos cuyos servicios se ven afectados o entran dentro del alcance de la auditoría, y evidencias del control realizado sobre estos servicios.

#### **Formalización del inicio de la actuación:**

El inicio de la actuación debe formalizarse mediante una notificación del responsable de la unidad de auditoría de la organización dirigida al responsable de la unidad auditada, en la que se identifique al equipo auditor y el objeto de la acción a llevar a cabo. En algunas ocasiones,

pueden darse circunstancias que lleven a que no se envíe notificación previa. Los trabajos siempre comenzarán manteniendo una reunión entre el equipo auditor y el máximo responsable de la unidad auditada, para dejar establecido el alcance y la planificación de los trabajos. Durante la entrevista, convenida de mutuo acuerdo y en la ubicación física de la unidad auditada, el equipo auditor describirá el proceso a llevar a cabo, el tipo de auditoría a realizar, la información que necesitará recopilar durante la actuación, las pruebas y verificaciones que se harán y la colaboración requerida por parte del personal del área para que haga accesible la información solicitada y permita la realización de las comprobaciones que determine el equipo auditor.

Se designará el interlocutor del área auditada para ayudar al equipo auditor, y se identificarán el resto de los interlocutores. Asimismo, si el área auditada deseara que fuera revisado algún proceso inicialmente no previsto, deberá señalarlo en esta fase de la actuación.

El equipo auditor debe tener presente que su trabajo debe minimizar las interferencias con el desarrollado en el área auditada, evitando realizar la actuación durante períodos de trabajo estacional; los auditados deben tener presente su deber de colaboración con el equipo auditor. Durante la auditoría se obtiene, analiza y documenta información de diversas fuentes, como registros informáticos, información documental, información testimonial (entrevistas, cuestionarios, informes solicitados,..) que requieren un trabajo de campo.

## **2. Examen y evaluación de la información obtenida en la fase previa:**

### **Trabajo de Campo:**

En esta fase del proceso de auditoría, el equipo auditor recopilará información adicional con el fin de obtener evidencias e identificar hallazgos que reflejar como conclusiones de la actuación. Si la unidad no ha sido previamente auditada, el esfuerzo para obtener evidencias puede ser importante ya que no se puede dar nada por conocido y todo debe ser recogido o contrastado con pruebas materiales. Si existiera una auditoría previa, el esfuerzo se centrará en identificar los cambios operacionales o técnicos desde la última actuación.

### **Evidencia:**

En auditoría se entiende por **evidencia** cualquier información empleada por el auditor para determinar si el proceso que se está auditando cumple con los criterios y objetivos de la auditoría. En el Diccionario de la Real Academia Española se define evidencia como "certeza clara y manifiesta de la que no se puede dudar", y en una acepción más jurídica como "prueba determinante en un proceso".

Las conclusiones que se reflejarán posteriormente en el informe de auditoría deberán estar basadas en evidencia suficiente, relevante y competente:

- **Suficiente:** En la cantidad necesaria para que puedan soportar las conclusiones del auditor, es decir que sean suficientes para persuadir a una persona razonable de la validez del resultado. Se pueden emplear métodos estadísticos para determinar el tamaño de las muestras o la cantidad de pruebas a realizar.
- **Relevante:** Si tiene relación lógica y ajustada al objeto de la actuación.
- **Competente:** Que sea válida, tenga calidad, y ser consistente con el hecho a demostrar.

Los auditores pueden encontrar útil obtener por escrito las opiniones dadas verbalmente por los responsables auditados, lo que confirmaría la competencia de la evidencia obtenida, y reduciría malas interpretaciones.

La forma de determinar la suficiencia, relevancia y competencia de una evidencia dependerá del **origen** de la misma:

- Datos obtenidos por el equipo auditor: Según el diseño y las técnicas de recolección de evidencias más adecuadas, y la habilidad del auditor para obtener los datos.

- Datos recogidos por los auditados: Podrán emplearse como evidencias determinando la validez y credibilidad de los mismos.
- El **grado de fiabilidad** de las evidencias que se obtengan dependerá de una serie de factores:
- Independencia del proveedor de la evidencia: Una fuente externa al área auditada será en un principio más confiable.
- Calificación del entrevistado: Debe determinarse su entendimiento técnico del área en revisión.
- Objetividad: Se primarán las evidencias objetivas frente a aquellas que requieran opinión o interpretación, ya que introducen subjetividad.
- Tiempo de disponibilidad: Considerar el tiempo durante el cual puede estar disponible la evidencia. Si es volátil, se debe emplear una técnica que asegure contar con ella.
- Según su **naturaleza**, las evidencias se pueden clasificar en:
  - Físicas: Obtenidas directamente por los auditores mediante inspección directa u observación. Pueden documentarse en memoranda, fotografías, dibujos o esquemas, muestras físicas.
  - Documentales: Documentos existentes, como cartas, informes, contratos, procedimientos, etc.
  - Testimoniales: Obtenidas del personal auditado como resultado de entrevistas, cuestionarios o listas de verificación.
  - Analíticas: Elaboradas por el equipo auditor mediante comparaciones, separación de información en componentes, cálculos o empleo de argumentos razonados.
- Finalmente señalar que, en todo caso, si se demuestra la **existencia de errores** en los datos que no podrán soportar la evidencia como válida, será necesario:
- Buscar otras fuentes de evidencia.
- Redefinir los objetivos de la auditoría para eliminar la necesidad de contar con datos.
- Usar los datos, pero señalando en el informe las limitaciones de los mismos, evitando hacer conclusiones o recomendaciones sin garantías.

Algunos ejemplos de evidencias válidos en el contexto de una auditoría serían:

- La obtenida de una tercera parte independiente es más competente que la ofrecida por el área auditada.
- La obtenida de un sistema con un control efectivo más que la ofrecida por un sistema con un control débil.
- La obtenida por el equipo auditor directamente en una inspección física frente a la obtenida indirectamente.
- Documentos originales frente a copias.
- Testimonios de personas que se expresen libremente frente al de personas coaccionadas.
- Evidencia frente a opinión de un experto.

En cuanto a las técnicas habituales para recopilar evidencias destacarían:

- **Revisión de documentos:** Permitirán que el equipo auditor adquiera el entendimiento del entorno de los sistemas a auditar. Los documentos a estudiar en primer lugar serán aquellos solicitados en la entrevista que formalizó el inicio de la actuación, o las que se mantengan con interlocutores de alto nivel. Se debe obtener información documental al menos sobre:

- Estructura organizativa: Organigramas, puestos de trabajo, definición de competencias y distribución de funciones, etc. Se buscará una adecuada separación o segregación de funciones, y el nivel de control que provee el modelo implementado.
- Políticas, normas y estándares: Se determinará su existencia y si son apropiados.
- Documentación de los sistemas de información: Se determinará la existencia, y si son apropiados (estudios de viabilidad, requerimientos funcionales de usuario, planes de prueba, manual operaciones, registros de cambios, manuales de usuario), documento relacionados con la seguridad (evaluaciones de riesgos, planes contingencia, etc.)

- **Entrevistas:** Tienen como finalidad la obtención de información y averiguar el grado de conocimiento de los entrevistados sobre el sistema de control que será objeto de la auditoría. Deben organizarse con antelación suficiente, siguiendo un patrón, y documentarse preferentemente con notas escritas. Como material de apoyo se pueden emplear listas de verificación o cuestionarios. Debe tenerse presente que el objeto de la entrevista es recoger evidencias por descubrimiento, y en ningún caso ser acusatorias.

Según el momento en que se realicen y el tipo de información recopilada, se pueden clasificar en:

- Preliminares: Se mantienen con interlocutores de nivel directivo alto/medio. Se debe aclarar el objeto o motivo de la actuación, así como la colaboración esperada. En esta fase se documentarán las entrevistas, se solicitarán organigramas, documentos de planificación general, y documentación sobre el sistema de control aplicado.
- De detalle: Se mantienen con los mandos con responsabilidad directa en la ejecución de los controles y con responsables técnicos. Se podrá solicitar cumplimentar un cuestionario detallado o una encuesta, y podrá requerirse documentación detallada sobre el proceso evaluado. Estas entrevistas permitirán posteriormente evaluar el cumplimiento de las normas, procedimientos y estándares reconocidos. Si durante ese proceso el equipo auditor encontrase controles y procedimientos operativos adecuados, procederá con las siguientes actividades previstas para la actuación. Si, por el contrario, se detectasen deficiencias significativas, los hallazgos deberán ser documentados e informados inmediatamente.
- De seguimiento: Durante todo el proceso de la auditoría se podrán mantener reuniones breves con la dirección del área auditada para informarle sobre los hechos observados en la actuación, y aclarar dudas o corregir malos entendimientos e inexactitudes. Se proporciona así la oportunidad a la unidad auditada de tomar inmediatamente medidas correctivas si fuese posible.

- **Pruebas y verificaciones de campo:**

- Pruebas de cumplimiento: Orientadas a comprobar que se cumplen determinados procedimientos de control o procesos establecidos y que funcionan según lo esperado.

Las pruebas se pueden emplear no sólo para probar la existencia de controles, sino para medir la efectividad del proceso de control. Ej.: verificar que en las librerías de programas las versiones de los programas fuentes y objeto son las mismas; asegurar

que se siguen pasos predefinidos para el paso a producción; comprobar que ningún usuario sin permisos pueda acceder a aplicaciones o a datos.

- Pruebas sustantivas (o de validación): Se aplican para detectar la presencia o ausencia de errores en los procesos o controles. Se pueden aplicar muestreos estadísticos o buscar específicamente las operaciones de mayor riesgo.

En ocasiones se pueden combinar una prueba de cumplimiento y una sustantiva, ej. El uso de datos de prueba que por generen errores lógicos en un programa, asegurando la existencia de controles que los detecten, y por además midan la exactitud de los cálculos, validando los mismos. La observación de la ejecución de los procesos y la intervención de las personas en ellos no deben obstruir en ningún momento el trabajo del área auditada. Ej. De pruebas sustantivas: verificar que se registran adecuadamente en el inventario informático la información requerida de los elementos; definir juegos de datos de prueba con los que se comprobará la integridad de cálculo de las rutinas de un programa de aplicación.

- **Hallazgos:** Sólo se podrán considerar como **hallazgos** de la auditoría a los criterios, condiciones y efectos que permitan documentar los problemas encontrados, que dependerán del objeto de la auditoría.

Se entiende por **criterio** un estándar empleado para determinar si el objeto de la revisión cumple las expectativas para lo que fue pensado, por ejemplo, estándares o normas técnicas.

Por **condición** se hace referencia a la situación que existe y se ha determinado y documentado durante la entrevista, por ejemplo, la falta de elementos de extinción de incendios.

Por **efecto** se define las consecuencias de una condición, que pueden variar un criterio identificado en la auditoría, y evidencian la necesidad de medidas correctivas, como, por ejemplo, la falta de extintores aumenta el riesgo de no poder controlar un conato de incendio.

#### **Impacto de un hallazgo según su materialidad:**

- **Bajo** → descripción del hallazgo como vulnerabilidad a la que se expone el sistema.
- **Medio** → se refleja en el informe como posible debilidad del sistema de control.
- **Alto** → se identifica como una debilidad que debe compensarse o anularse con más controles, o haciendo los existentes más estrictos.

#### **Evaluación de los trabajos:**

Al finalizar los trabajos de campo, el equipo de auditoría deberá revisar toda la información recopilada, así como los hallazgos. En esta fase se valorará el cumplimiento de las normas, de los procedimientos y de los estándares reconocidos, y se determinará si los procedimientos tienen una estructura de control adecuada, que sea efectiva en términos económicos, y que provea una adecuada seguridad para que las tareas se realicen según lo previsto, y que el objetivo o punto de control se cumple. Todo el análisis debe estar justificado con evidencias recogidas en la actuación.

En la Guía 802 para la realización de las pruebas de auditoría determinar que el auditor tendrá en cuenta como normas generales, las siguientes premisas:

- La planificación de las pruebas a realizar, especialmente las de observación y pruebas técnicas, es un elemento privativo del equipo auditor.
- En la realización de determinadas pruebas como la verificación documental de autorizaciones, aprobaciones o contratos, el auditor podrá requerir la revisión de los documentos.

- La muestra seleccionada de medidas o documentación debe ser suficiente y relevante para satisfacerse del cumplimiento objetivo de la prueba, dentro del alcance y objetivo de la auditoría.
- El equipo auditor no prejuzgará, a priori, en la existencia de determinadas medidas, ni será inflexible en su funcionalidad. Al evaluar las medidas existentes deberá siempre considerar, objetivamente, si se ajustan a lo previsto por el RD 3/2010 y si previenen realmente los riesgos identificados en el Análisis de Riesgos.
- Ante la ausencia de determinada medida, se investigará y analizará si existen otras medidas compensatorias, y en su caso, se evaluará la eficacia de estas últimas.
- Las entrevistas no se plantearán de forma inductiva (conducir a una contestación concreta), sino abiertas (cómo se realiza determinada actividad o se concreta en la práctica determinada medida de seguridad).
- Se ponderarán las respuestas de las entrevistas, pudiendo haber lugar a la realización de pruebas complementarias que no estaban previstas.

Para las evidencias de las pruebas el auditor tendrá en cuenta como normas generales, las siguientes:

- El Jefe del equipo auditor deberá supervisar todo el trabajo realizado y comprobar que se ha llevado a cabo el programa de auditoría previsto y aprobado, y que las desviaciones al programa, o sus modificaciones, están debidamente fundamentadas, y registradas.
- La evidencia recogida debe ser suficiente y relevante para que:
  - si no hay incidencias a comunicar, se acredite la realización adecuada de la prueba y sus resultados.
  - si hay incidencias a incluir en el informe, se sustente claramente el incumplimiento persistente o una indiscutible deficiencia de seguridad, y no aquellas situaciones excepcionales o puntuales, si están reportadas, controladas, y aprobadas, a menos que la excepcionalidad no debiera haber sido aprobada, por el riesgo que pudiera implicar, según el juicio objetivo y sustentado del auditor.
- La revisión de documentación (incluyendo el análisis de riesgos) deberá documentarse con las conclusiones de la revisión, y las posibles aclaraciones recibidas posteriormente.
- Las conclusiones o información recogida en una entrevista, para poder ser consideradas como evidencias de auditoría, deberán ser plasmadas en actas comunicadas a las personas entrevistadas.
- Los correos electrónicos, en la medida que involucre a varias personas dentro del alcance de la auditoría, y se disponga del acuse de recibo, pueden servir, en determinados casos, también como prueba de auditoría.
- Las pruebas de observación (por ejemplo, seguridad física) deberán estar documentadas ya sea a través de fotografías, documentación similar, o comunicaciones escritas puntuales<sup>2</sup> al Responsable de Seguridad.
- Las evidencias que se recojan deben evitar, en lo posible, contener datos de carácter personal, o si es necesario como evidencia, que los contengan, debe utilizarse algún mecanismo (supresión, tachado, etc.) que impida su divulgación.
- Las evidencias que haya que presentar a requerimiento de quien tenga competencias para solicitarlas, deberán acogerse a la práctica habitual y en particular, si se trata de evidencias electrónicas, deberán someterse a las Normas Técnicas de Interoperabilidad que resulten de aplicación.

- Los documentos de trabajo del auditor (planificación, documentación revisada, evidencias, actas de reuniones, listados, copias de pantallas, y evidencias similares del trabajo realizado, ya sean en soporte papel o electrónico) deberán mantenerse como mínimo durante los dos siguientes años, debidamente referenciados y archivados, así como custodiados y protegidos.

### 3. Comunicación de los resultados.

La comunicación de los resultados obtenidos en la auditoría se realiza mediante **informes de auditoría**. Al final del proceso de la auditoría se mantendrá una **reunión de cierre** con el máximo responsable de la unidad auditada (quien haya participado en la reunión de lanzamiento), con objeto de comunicar los principales hallazgos de la actuación. Tras la cual el equipo de auditoría comienza a redactar el **borrador del informe**, que incluirá todos los hechos, hallazgos, conclusiones y recomendaciones. La redacción debe ser clara y concisa. Los informes de auditoría deben someterse a un **procedimiento de tramitación**, generalmente contradictorio. Esto significa que el órgano o entidad auditada tienen la posibilidad de plantear, en un plazo prefijado, **observaciones o alegaciones** al informe preliminar, que son evaluadas por los auditores al elevar el informe definitivo.

La Guía 802 explica que el objetivo principal de la presentación de los resultados de las revisiones y pruebas, antes de la emisión del informe de auditoría, es confirmar los hechos y las situaciones detectadas o identificadas como resultado de las pruebas y revisiones realizadas. Esta presentación tendrá un carácter aséptico, sin valoraciones subjetivas, ni aludiendo a la valoración de los resultados finales a plasmar en el informe, que es la opinión profesional del auditor.

Esta presentación es fundamental para la eficacia del informe de auditoría posterior, al confirmar que los resultados, de las revisiones y las pruebas, son ciertos, y que no existe otra información, que por no haber sido considerada o no estar disponible en su momento, podría cambiar la evaluación del cumplimiento de determinado requisito de seguridad.

Todos los resultados de pruebas, relacionados entre sí o que se refieran a una misma deficiencia o debilidad, se agrupan en el informe.

En relación con los requisitos del Título VIII del RD 1720/2007, cuando haya una divergencia contrastable entre la aplicación de estos y los del RD 3/2010, resultando un incumplimiento del primero, se debe indicar con claridad esta situación, ya que los requisitos del RD 1720/2007 son prioritarios, como desarrollo de una ley orgánica (Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal).

Aunque el objeto de la auditoría es el cumplimiento aceptable del RD 3/2010, el equipo auditor deberá tener en cuenta que estos requisitos son mínimos y por lo tanto, si observara alguna deficiencia que puede implicar riesgos en la protección de la información, deberá comunicarlo.

### 4. Seguimiento continuo.

En el informe se podrá señalar que las recomendaciones que deben ser llevadas a cabo en un período de tiempo determinado a contar tras su recepción, o ser la dirección de la organización quien decida cuándo y cómo llevar a cabo las **recomendaciones**. En las recomendaciones el auditor propone **soluciones** a los problemas detectados basadas en su experiencia profesional y plantea mejoras con vistas a conseguir que la organización cumpla sus objetivos. No suelen ser directamente ejecutivas (de obligado cumplimiento por parte del auditado).

### 36.04.02 Guías de Auditoría de los sistemas de información (guion, puntos de control)

Aunque cada auditoría es única, se pueden encontrar similitudes entre ellas para los mismos objetivos de control, y en especial si tienen un carácter periódico.

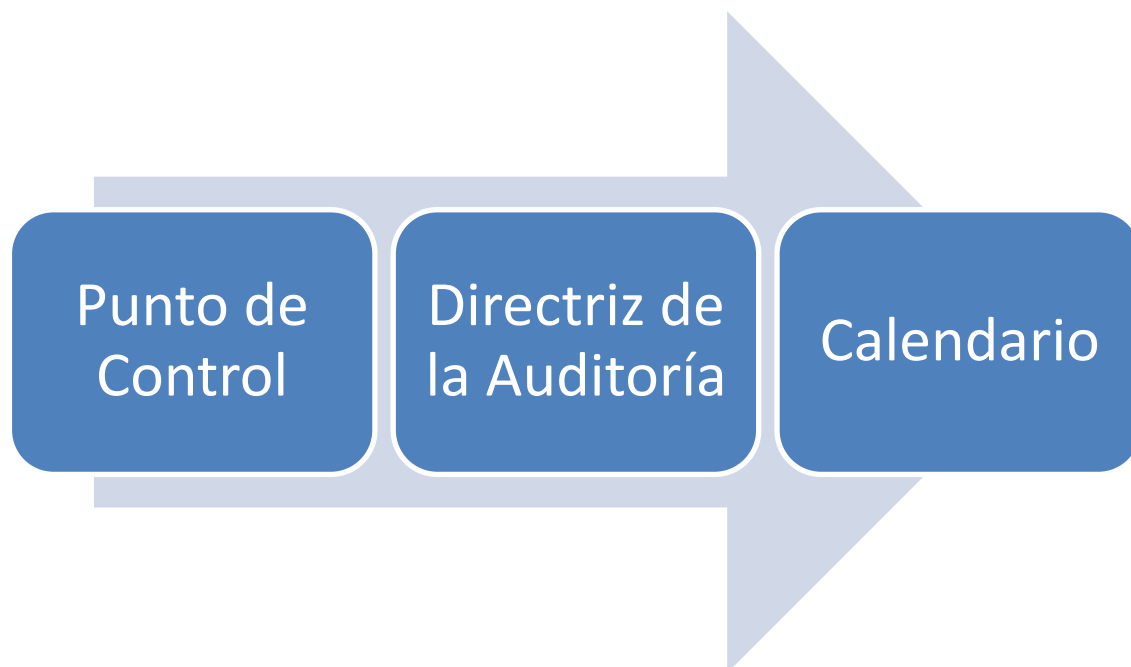
El guion, los documentos preliminares empleados para su elaboración, y los documentos en que se apoyarán las evidencias que se recogerán durante los trabajos de campo, constituyen los conocidos como **papeles de trabajo**, que tienen los siguientes fines:

- Son el principal soporte para la elaboración del informe de auditoría.
- Ayudan al auditor a llevar a cabo la auditoría.
- Permitirían a terceros evaluar la calidad de las acciones realizadas.

En cualquier caso, debe tenerse presente que el guion elaborado en la fase inicial de la auditoría es necesariamente un documento vivo, ya que al comenzar a desarrollar los trabajos puede ser necesario modificar las tareas previstas inicialmente, ya sea en su número como en su detalle, para ajustarlas a lo que se vaya percibiendo durante la actuación. Por lo tanto, durante la actuación el guion irá reflejando las actividades realmente desarrolladas en la actuación, y la versión final deberá incluir:

- Objetivos, alcance y metodología empleada, señalando los criterios a utilizar para recoger las muestras a emplear en la realización de las pruebas.
- Documentar el trabajo realizado para soportar las conclusiones del informe.
- Evidencias para la revisión del trabajo realizado, señalando las referencias al resto de los papeles de trabajo.

En la siguiente figura se resume el esquema para elaborar el guion de una actuación.



• **Punto de control:** Señala el objetivo de control a supervisar para ver en qué forma se tienen identificados y bajo control los riesgos asociados. En función del objetivo y alcance de la actuación podrán definirse varios puntos de control, que serán las consideraciones genéricas a tener presentes durante la actuación.

· **Directriz de auditoría:** Para cada punto de control identifica qué tareas deben efectuarse con carácter previo o durante la actuación, desde la obtención de la comprensión del entorno a auditar (incluida la obtención de evidencias), la evaluación de los controles existentes, la valoración de la suficiencia y adecuación de los mismos, y la justificación de los hallazgos. El nivel de detalle de las directrices dependerá de los puntos de control, determinará los medios y las técnicas de auditoría que deben emplearse, lo que condicionará el calendario de la actuación.

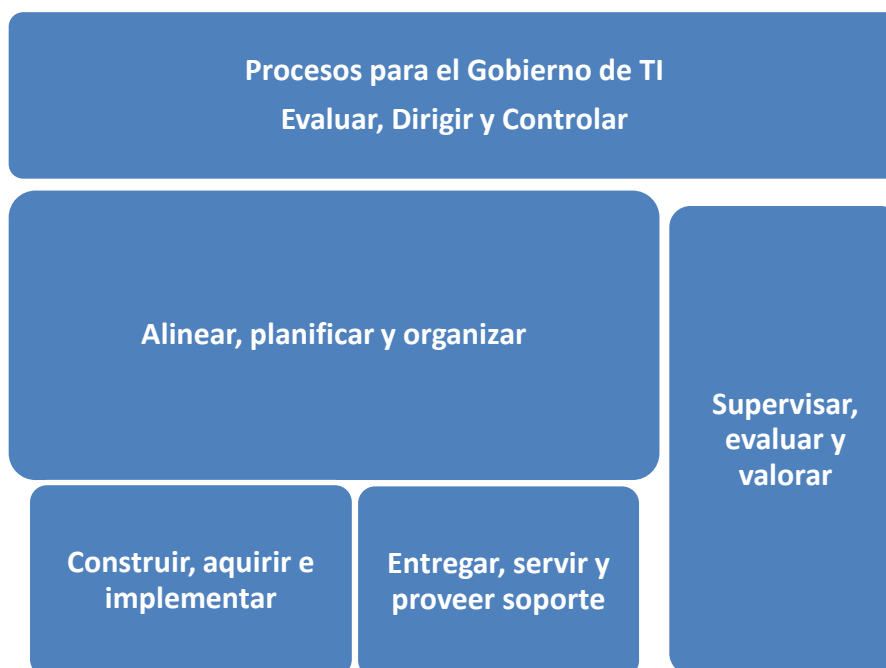
- **Identificación de medios:** En función de las directrices se identificarán con qué medios humanos y técnicos se llevará a cabo la actuación. Si las habilidades o conocimientos del equipo propio no se ajustasen a lo requerido, o se vieran inhibidos por haber participado en el desarrollo de una actividad en el área auditada, será necesario llevar a cabo la contratación de un servicio de apoyo externo. En cuanto a los medios técnicos, una vez identificados podrá ser necesaria la adquisición de alguna herramienta de auditoría para facilitar la obtención o análisis de evidencias. En ambos casos, estos hechos deberán tener reflejo en el calendario previsto.
- **Técnicas a emplear:** Identifican cómo se desarrollarán las tareas durante la actuación. Y se han comentado, brevemente a modo de resumen:
  - ▶ Solicitud y revisión de documentación.
  - ▶ Entrevistas: Requieren su preparación previa realizando una relación de los temas a tratar, que no será cerrada para evitar excluir asuntos que pudieran ser de interés.
  - ▶ Encuestas: el documento o cuestionario debe contemplar en cada pregunta un apartado para observaciones cuando se requieran aclaraciones, o cuando exista la posibilidad de responder "Otros". Las encuestas pueden ser remitidas a los encuestados para que sean completadas, y podría considerarse que fueran anónimas.
  - ▶ Observación del trabajo realizado: Consiste en comprobar cómo un usuario o profesional realiza su trabajo y que los resultados obtenidos se ajustan a lo esperado, es decir, que la eficiencia sea óptima. Para verificar los controles establecidos se podrá solicitar la ejecución de situaciones de riesgo o simular errores, evidenciar carencias o vicios adquiridos, etc.
  - ▶ Pruebas de cumplimiento: Comprobaciones para determinar qué procedimientos o controles específicos están adecuadamente establecidos, recogiendo evidencias de registros, documentos, observación del funcionamiento de pruebas específicas.
  - ▶ Pruebas sustantivas: Comprobación de la existencia o ausencia de errores o irregularidades, en especial cuando hay evidencia de controles insuficientes, carencias o vicios adquiridos, etc.
  - ▶ Uso de herramientas informáticas: pueden ser específicas para la generación de muestras, o las de la organización para interrogar los sistemas de información o para extraer información que luego será tratada por otra herramienta de análisis. Si los sistemas evaluados incorporan pistas de auditoría, éstas serán una valiosa fuente de información.

· **Calendario:** Es fundamental realizar una planificación de las tareas identificadas señalando en qué momento de la actuación se llevarán a cabo. En todo caso, se negociará con ellos las fechas de las actuaciones y se les notificará la planificación resultante para las entrevistas y comprobaciones. Si la metodología marco empleada como instrumento es COBIT, ésta ya cuenta con una directriz genérica para elaborar el guion de una actuación, según la siguiente figura.

El Comité Directivo de CobiT en su v4 y el IT Governance Institute ha elaborado el documento "Directrices de Auditoría", que señala para cada uno de los 34 objetivos de control de alto nivel los pasos a seguir, indica las directrices de auditoría detalladas a tener en cuenta y las herramientas de auditoría a emplear en la actuación. Aunque dado lo genérico del

planteamiento de COBIT, el auditor debe adecuar lo señalado por la metodología y hacerlo aplicable al entorno de la organización auditada.

En la versión 5 de CobiT se establece un nuevo marco de procesos:



Siendo en el proceso de Supervisar, Evaluar y Valorar donde la auditoría juega un papel más relevante.

### **Puntos de control**

Si la metodología empleada es COBIT los puntos de control se obtienen a partir de los objetivos de control de alto nivel, los que a su vez se subdividen en otros con mayor detalle. Cabrían consideraciones similares al emplear otras referencias metodológicas que señalan las mejores prácticas, como ITIL para la gestión de servicios TIC, o ISO/IEC 27000 para los sistemas de gestión de la seguridad de la información.

Considerando que las auditorías informáticas suelen enfocarse en el análisis de situaciones de riesgos informáticos en áreas de actividades concretas, por ejemplo la seguridad física de los locales del centro de tecnologías de la información o la seguridad lógica de los sistemas de información, en este apartado se señalarán los principales puntos de control a tener en cuenta según la naturaleza de la auditoría.

Se enumeran, sin ser muy exhaustivo, algunos de los puntos de control más habituales según tipos de auditoría.

### **Auditoría de la dirección de tecnologías de la información**

Se dirige a evaluar las áreas de riesgo relativas a cómo se planifican, organizan, coordinan y controlan las actividades propias del órgano con responsabilidad y competencias en TIC. Los controles a tener en cuenta serán:

- Planificación: Comité para la planificación y seguimiento de actividades TIC, existencia de un Plan Director o Estratégico de Sistemas de Información y Comunicaciones, otros planes relacionados.

- Organización y coordinación: Ubicación de la Unidad con competencias TIC dentro de la Organización, descripción de funciones y responsabilidades de la Unidad TIC, marco metodológico, recursos humanos, gestión económica, gestión de proyectos.
- Protección contra delitos informáticos: medidas preventivas y controles sobre los sistemas de información para evitar su uso no autorizado o el de los datos, ya sea por personal propio, personal de apoyo o terceros.
- Control interno: Definición de políticas y su desarrollo normativo, seguimiento, directrices de auditoría interna, ajuste a la normativa vigente.

### **Auditoría de la seguridad**

Estas actuaciones se dirigen a evaluar la función de seguridad en la Organización, y cómo se articulan las medidas para controlar las vulnerabilidades de los entornos físicos y lógicos TIC.

- Prácticas Comunes de Seguridad: Aspectos organizativos, políticas de Seguridad aplicados a los sistemas TIC, planes para contingencias y desastres, programas de seguridad, aspectos de personal, seguridad en los accesos de terceras partes a los sistemas TIC, cesión de datos e intercambio de información con terceras partes, gestión de incidencias, documento de seguridad de los datos de carácter personal.
- Objetivos de la Seguridad Física: Entornos físicos e inventario de activos a proteger, establecimiento de áreas seguras, protección contra siniestralidad natural y delictiva, protección contra el fuego, suministro eléctrico, perímetro de seguridad física y su protección contra la intrusión, controles de accesos a las instalaciones, protección de medios empleados para el respaldo de la información, seguridad en la reutilización o eliminación de equipos y soportes magnéticos, actuación en caso de sustracción de equipos, contratos de soporte, asistencia, servicios de seguridad y pólizas de seguros, mecanismos para la resolución de incidencias.
- Objetivos de la Seguridad Lógica: Inventario de activos a proteger, proceso de autorizaciones, restricciones de acceso lógico a los sistemas, gestión de cambios en el software, mecanismos para el respaldo del software y datos seguridad de los datos, monitoreo y detección de actividades ilícitas.

### **Auditoría del equipamiento informático**

- Planificación de la infraestructura tecnológica: Acciones para determinar el ajuste y la evolución de la infraestructura a los cambios tecnológicos y al soporte de la actividad de la organización, plataforma HW y plataforma SW.
- Inventario: Se detectará el ajuste de los medios empleados a la legalidad vigente, y su uso como herramienta para la planificación de otras áreas, registro de los componentes, requerimientos legales y contractuales, planificación de recursos.
- Mantenimiento HW: Se pasará revista a los procedimientos seguidos para asegurar la correcta operatividad del equipamiento informático, adecuación del personal propio, garantías de los productos, gestión de los contratos de mantenimiento, gestión de incidencias.
- Puestos de trabajo: Las acciones se pueden orientar en el análisis de la especialización, la protección de los recursos, los estándares de hardware y software, la protección de programas de ordenador, el almacenamiento de información, la formación, el soporte a usuarios, etc.
- Redes de área local: La actuación se orientará a la evaluación de los controles establecidos para minimizar los riesgos asociados en las áreas centradas en desarrollo, explotación, seguridad y comunicaciones, arquitectura y organización, aplicaciones soportadas en red, gestión de la red, seguridad de la red.

### **Auditoría de los desarrollos y mantenimiento de los sistemas de información**

Las acciones de verificación comprenderán todo el ciclo de vida del desarrollo de un proyecto, es decir desde que se toma la decisión de realizar un desarrollo hasta la entrega del mismo.

Estos pasos generalmente se traducen en las siguientes fases de la actuación:

- Metodologías empleadas
- Sistema de dirección
- Inicio del proyecto

Estudio de viabilidad:

- Fase de diseño
- Fase de desarrollo
- Fase de producción y mantenimiento

### **Auditoría de la explotación de los sistemas de información**

Estas acciones tienen por objeto asegurar la correcta y segura operación de los recursos para el tratamiento de la información.

- Procedimientos y responsabilidades de operación: Documentación de los procedimientos operativos, control de cambios operacionales, procedimiento de gestión de incidencias.
- Planificación de los trabajos.
- Segregación de tareas dentro de la Unidad: Separación de recursos, entorno de pruebas, gestión de recursos externos.
- Protección contra software malicioso en productos externos o en desarrollos propios.
- Utilización y seguridad en los soportes de información.
- Intercambio de información con el exterior.
- Protección contra fraudes informáticos: medidas técnicas y organizativas adoptadas para evitar el uso fraudulento de datos o aplicaciones, o para contrarrestar posibles ataques informáticos (caballo de Troya, puertas falsas, ataques internos, ataques externos, sustitución de la identidad, pinchado de líneas, etc.)

### **Auditoría de la contratación de bienes y servicios TIC**

En estas acciones de auditoría se verificarán las políticas y los procedimientos de adquisición establecidos por la Organización. Dado que en la Administración Pública los organismos están sujetos al marco que establece la Ley de Contratos, su reglamento, así como otras disposiciones normativas; la auditoría se centrará en verificar el cumplimiento de los mismos.

Además, debe asegurarse que la interpretación del marco legal se ha implementado con procedimientos internos adecuados, y que los mismos aseguran los principios de transparencia e igualdad de oportunidades para que los posibles oferentes puedan realizar la oferta más conveniente para la Organización.

- Organización de la contratación: Se analizará la fluidez y operatividad de las relaciones con otras unidades de la Organización o externas que intervienen en el proceso de contratación.
- Criterios seguidos en la planificación de las contrataciones: Área responsable, ajuste a los planes estratégicos y partidas presupuestarias, mecanismos para hacer frente a las demandas extraordinarias, criterios usados para la determinación de los techos presupuestarios.
- Políticas y criterios para la adquisición de bienes y servicios informáticos: Formación en contratación TIC del personal técnico directivo, criterios de contratación (tipos de contratos), objeto del contrato con adecuado nivel de detalle, requisitos mínimos

detallados y cuantificados, criterios de adjudicación objetivos, clausulado especial incluido en los pliegos de cláusulas específicas, criterios seguidos para la adjudicación de los contratos.

### **Otros tipos de auditorías de sistemas de información**

- Control de accesos
- Bases de datos
- Técnica de sistemas
- Calidad de los productos desarrollados
- Seguridad en las comunicaciones
- Gestión de la continuidad del servicio informático
- Acreditación de servicio de confianza.

También se debe hacer mención a las actuaciones de auditoría de sistemas de información que cubran requerimientos dados por la normativa vigente en España, tales como Protección de datos (**Ley Orgánica 15/1999**, de protección datos de carácter personal (LOPD) y por su reglamento) aunque con el marco de actuación de la Guía 802 lo más sensato es hacer coincidir en el tiempo la auditoría de seguridad y la de protección de datos. Para más información consultar la Guía 802 al completo.

### **36.04.03 Informes de auditoría**

El objetivo fundamental del Informe de Auditoría es la comunicación de los resultados de la actuación a los usuarios u órganos directivos competentes de la organización. Su redacción debe ser clara para evitar en lo posible que se preste a interpretaciones diferentes a las que el auditor hubiese concluido. El informe además servirá para facilitar el seguimiento y comprobar posteriormente que se han tomado las acciones correctivas adecuadas.

. **Asunciones:** Todo lo que se refleje en el informe de auditoría debe ser consecuencia de asunciones explícitas, probadas y que puedan ser desafiadas. El auditor tendrá presente que del informe podrá derivarse la toma de decisiones por parte de la dirección de la organización, por lo que debe asegurarse un profundo entendimiento del contexto en el cual se trabaja, y considerar las opciones disponibles en términos de prioridades y expectativas de la organización. El informe debe redactarse con la habilidad suficiente para que la organización pueda ser capaz de ejecutar los resultados según lo esperado.

. **Leguaje empleado:** Se cuidará la consistencia gramatical (tiempos verbales, etc.), se evitará el empleo de frases ambiguas o no definitorias en las conclusiones (podría ser..., posiblemente..., etc.), se enfatizarán las propuestas en las recomendaciones (deberá en lugar de debería, etc.).

Se evitará el empleo de tecnicismos propios de las TIC, en especial cuando los destinatarios del informe no sean técnicos en la materia. En todo caso, si fuese difícil evitar la referencia o el empleo de términos técnicos, se incluirán las definiciones o la explicación del acrónimo empleado.

. **Versión del informe:** La primera versión de la redacción será el **borrador del informe**, que debería ser cumplimentado lo antes posible, e incluirá todos los hechos, conclusiones y recomendaciones. El borrador se remitirá a la dirección del área auditada, acompañado por un requerimiento para que en un plazo establecido se remitan por escrito los comentarios que se estimen convenientes, dejando constancia que el borrador es un documento de trabajo en elaboración, por lo tanto sujeto a revisión, y su calidad de documento reservado.

Al final del período de respuesta, y después de revisar y en su caso tomar en consideración las observaciones remitidas por el área auditada sobre el borrador, se elaborará el **informe final de la auditoría**. Si el equipo de auditoría no coincidiese con alguno de los comentarios

realizados sobre el borrador, deberán ser explicadas las razones e incluidas en el informe final, que a su vez incluirá la respuesta recibida.

**. Distribución del informe:** El informe se distribuirá a quienes, en función de la normativa interna establecida, sean competentes para conocerlo. Cuando los contenidos del informe sean considerados como sensibles para los intereses de la organización, se asegurará la restricción de la circulación del informe, que se reflejará en el propio informe para garantizar el grado de confidencialidad requerido.

**. Otros entregables:** Las recomendaciones incluidas en el informe podrán dar lugar a **instrucciones** en un documento independiente, que serán dirigidas a la dirección de la unidad auditada, sugiriendo acciones para resolver las incidencias detectadas en el sistema de control. Si el informe es muy extenso o muy técnico, sería conveniente la preparación de un **resumen ejecutivo** para que pueda ser analizado con detenimiento por los órganos de dirección.

En cuanto al contenido del informe de auditoría, todos los informes contendrán unos apartados comunes, que constituirán la estructura del mismo, con unos contenidos mínimos:

**Título:**

Debe servir para distinguirlo de cualquier otro de forma inequívoca, señalando sintéticamente el ámbito de la actuación, el alcance y la Unidad auditada, y la fecha de ultimación. Podrá incluir un código a fin de facilitar su identificación, archivo y recuperación posterior.

**Índice:**

Recogerá todos los apartados incluidos en el informe, con referencia a las páginas de su ubicación, y se incluirá la relación de los anexos que el informe pudiera tener.

**Introducción:**

Se explicitarán las razones por las que se realiza la actuación de auditoría, haciendo constar sobre la base de qué mandato o en función de qué competencia se ha decretado la auditoría. Además, se indicará el calendario de los trabajos de campo y los componentes del equipo de auditoría.

**Objetivo y alcance del trabajo desarrollado:**

Se señalará claramente el objetivo perseguido y el tipo de auditoría efectuada. El alcance de la actuación deberá estar en consonancia con los objetivos, señalando la profundidad del trabajo realizado, mencionando expresamente las técnicas empleadas y el tipo de comprobaciones efectuadas para evaluar la información. Será necesario establecer qué temas no han sido contemplados o se han excluido de la actuación (las limitaciones del alcance del trabajo). Si no existiera ninguna restricción significativa, se haría constar expresamente.

**Metodología:**

En este apartado se describirán sucintamente las tareas realizadas en el curso de la actuación. Se pueden reflejar las pautas tenidas en cuenta para cada área de riesgo o punto de control evaluado, describiendo las directrices de auditoría contempladas en el guion empleado en la actuación. Por ejemplo, si se han empleado técnicas de muestreo distinguiendo si fue aleatorio o no, hacer constar las prácticas realizadas (reuniones, entrevistas, encuestas, verificaciones, etc.), identificar los interlocutores por su cargo o puesto (y no por su nombre), indicar los documentos solicitados al órgano auditado (se incluirán en los anexos si contribuyen a la motivación de la exposición).

**Resultados de la actuación:**

Este apartado describirá y documentará las actuaciones realizadas y las evidencias obtenidas, que darán lugar a las conclusiones y propuestas del informe. Deberán documentarse los resultados para cada punto de control incluido en el alcance. El texto, así como lo dicho para las evidencias, será el suficiente, competente y relevante, con la

finalidad que lo expuesto pueda ser comprendido adecuadamente (evitar tecnicismos, o si no es posible incorporar un glosario de términos en el anexo), los hechos deben presentarse de forma convincente e imparcial.

En función del tipo de auditoría se abrirá un epígrafe para cada una de las áreas objeto de control, aunque su estructura estará condicionada por la metodología empleada durante la actuación (entrevistas, requerimientos de información, obtención de información propia, etc.).

Para **estructurar los resultados** de una forma convincente se podrá seguir el siguiente proceso en la exposición de los elementos:

- Criterio: Descripción de los estándares empleados para determinar si un programa de control alcanza los resultados esperados. Los auditores emplearán los fijados por el Plan de Actuación o los que consideren razonables y relevantes en la materia auditada, como por ejemplo: fines señalados por la normativa vigente, normas técnicas o estándares, opiniones de expertos, rendimientos en períodos anteriores, o en organismos públicos similares o en el sector privado.
- Condición: Situación encontrada, que ha sido determinada y documentada durante la auditoría.
- Efecto: Puede ser la medida de la consecuencia positiva o negativa de la variación de la condición respecto de los criterios determinados, o bien el impacto logrado por la aplicación de un programa para cambiar ciertas condiciones.
- Causa: Motivo de la desviación de los rendimientos fijados (**auditorías operativas**) o del cumplimiento de pautas preestablecidas (**auditoría de cumplimiento**). La identificación de la misma es esencial para que los auditores puedan proponer recomendaciones constructivas, que serán tanto o más persuasivas en cuanto se pueda demostrar y explicar con evidencias y

Razonamientos la relación de los problemas con los factores identificados como causa. En el caso de **auditorías operativas** las conclusiones deben ser claramente expresadas y no reducirse a meras sugerencias, y la fuerza de las mismas dependerá de la naturaleza persuasiva de la evidencia que soporte los resultados, y de lo convincente que sea la lógica empleada en su formalización.

Si los hechos no son de fácil cuantificación las conclusiones corren el riesgo de estar influidas por interpretaciones y motivos subjetivos, por ello deben ser lo más objetivas posibles, evitando pronunciamientos globales y generales, salvo que éstos se limiten a constatar la existencia o no de controles para evaluar el funcionamiento del área auditada.

En las **auditorías de cumplimiento** cuyo objeto sea la verificación de los controles internos, las debilidades significativas detectadas y que merezcan ser comunicadas serán consideradas como deficiencias, y así deberán incluirse en el informe. En caso de que las hubiera, también se señalarán las fortalezas de los controles implementados.

Se incluirán en el informe todos los incumplimientos y abusos significativos que hayan sido detectados durante o en conexión con la auditoría. El término incumplimiento comprende actos ilegales e inobservancia de normas o controles internos. Por abuso se entenderá toda conducta que se desvía de las expectativas de conducta deseable.

Si el informe se realiza como consecuencia de una auditoría anterior, cada epígrafe señalará las medidas que el gestor haya decidido adoptar como consecuencia de las conclusiones y recomendaciones contenidas en los anteriores informes.

### **Conclusiones y recomendaciones:**

Este apartado del informe constituye el cauce para la formulación de las propuestas, siendo sin duda la parte más relevante y probablemente la más leída del informe.

Las **conclusiones** deben redactarse de forma que se puedan comprender sin necesidad de acudir al resto del informe, o a sus anexos, y recogerán todos los hechos significativos detectados en la actuación. En caso de que los auditores no hayan aplicado suficientes pruebas y procedimientos de auditoría para alcanzar un dictamen profesional, tendrán que hacerlo constar en el informe, señalando los motivos.

Con objeto de facilitar una actuación de seguimiento de las recomendaciones de una auditoría anterior, en el informe se deberá manifestar la situación en que se encuentran los defectos significativos puestos de manifiesto entonces y no corregidos, así como identificar las posibles consecuencias negativas que pudieran derivarse de no corregir las deficiencias señaladas en la ocasión anterior.

Caben distintas formas para redactar las conclusiones. Las más frecuentes son:

- De forma descriptiva: Descripción de los hechos más significativos en cada uno de los ámbitos o aspectos auditados, contemplando la situación actual y considerando dentro de ella las evidencias testimoniales, las documentales y, eventualmente, las analíticas. Se podrán orientar a evaluar la eficacia o eficiencia de los controles implementados. Este criterio es aplicable en auditorías operativas o de cumplimiento.
- Dictamen: Juicio crítico que determinará el grado de ajuste de los controles a lo esperado. Si el resultado es conforme, podrán emplearse términos como "Favorable" o "Cumple", en caso contrario "Desfavorable" o "No cumple". No obstante, si el cumplimiento con el control evaluado admite una cuantificación, se podrá aplicar una valoración del grado en que se alcanza el cumplimiento, como "Cumple parcialmente". Este criterio es aplicable en auditorías de cumplimiento.
- Grado de madurez: Evaluación de cuán bien se gestionan los controles de las áreas auditadas. En este caso, para cada punto de control se aplicará una escala de medición incremental sobre la forma en que se gestiona el riesgo. Este criterio es aplicable en auditorías operativas.

Las **recomendaciones** se efectuarán cuando supongan una potencial mejora en el funcionamiento, en especial cuando se detecten casos de incumplimiento significativos o se encuentren puntos débiles en el sistema de control, y harán referencia a las conclusiones de las que se derivan. Deben tener un carácter ejecutivo, es decir, comprometerán a la organización para su realización, ya que ponen en evidencia deficiencias del sistema de control. Las recomendaciones serán descripciones de las tareas más importantes a realizar para asegurar los mejores controles posibles, y serán tanto más útiles cuanto que se dirijan a resolver las causas de los problemas detectados, deben guardar una debida proporción en materia coste-beneficio con la escala de la organización.

El informe no sólo reflejará desviaciones negativas, sino que hará constar los logros más notables alcanzados por la unidad auditada, en particular cuando las mejoras de las prácticas puedan ser aplicables por otras áreas de la organización. Si se sospecha que la inclusión en el informe de ciertas informaciones o conclusiones puede condicionar una futura investigación, se limitará a las materias que no comprometan tales investigaciones. En todo caso, deberá ponerse en conocimiento de la alta dirección o del Servicio Jurídico las prácticas irregulares detectadas.

Si durante el transcurso de la actuación se descubrieran cuestiones importantes no relacionadas con el objeto de la auditoría que se está realizando y que requieran un trabajo adicional, deberán reseñarse en el informe junto con las razones que justifiquen un trabajo suplementario posterior, de cara a que se tenga en cuenta en la planificación de auditorías futuras.

#### **Anexos:**

La necesaria concisión de los informes de auditoría recomienda la elaboración de anexos que incluyan detalles e informaciones adicionales que contribuyan a una mejor comprensión de los aspectos más importantes incluidos en el informe.

Se podrá incluir la descripción del procedimiento auditado, los listados solicitados, información recopilada durante la actuación (evidencias), o cualquier otra información que se considere relevante.

Otras cuestiones que se pueden incluir en el informe:

#### **. Fecha de emisión y firma:**

El informe deberá estar fechado, con la fecha del momento final de su elaboración, haciendo constar la fecha del último día de trabajo de campo.

El informe deberá ir firmado y rubricado en todas sus páginas por el auditor encargado del trabajo, y podrá contener las condiciones profesionales del equipo de trabajo.

#### **. Plazo de entrega**

Los informes deberán presentarse en las fechas establecidas. Si los hechos identificados durante la actuación fueran considerados de importancia, se podrán emitir informes previos parciales, ya que puede ser conveniente una actuación correctiva inmediata.

En los informes parciales debe dejarse claro su carácter provisional y que en ningún caso serán sustitutivos del informe final, ya que éste recogerá con detalle los aspectos incluidos en los informes previos parciales. Otra característica de los informes parciales es que deberán ser breves y expondrán en forma resumida los problemas, causas y medidas correctivas recomendadas.

Aunque el informe se haya preparado con minuciosidad puede tener poco valor para quienes deban tomar decisiones si llega demasiado tarde. Es por ello que en la planificación de las tareas debe contemplarse este hecho, y respetar la fecha establecida para su entrega.

#### **. Alegaciones de los auditados**

Un elemento sustancial para asegurar la calidad del informe y que éste sea completo y objetivo es conseguir que los responsables de la actividad realicen una revisión del borrador del informe y formulen las alegaciones y comentarios que consideren oportunos. Al incluir las alegaciones de los auditados se logra que los informes no sólo indiquen lo que se descubre y la opinión de los auditores acerca de tales hechos, sino también lo que piensan sobre ello los responsables y qué es lo que se proponen hacer al respecto.

Las alegaciones deben constar por escrito, serán evaluadas objetivamente e introducidas en el informe final. Cuando estos comentarios sean contrarios a los juicios y conclusiones que aparecen en el borrador del informe, al auditor debe considerar las siguientes alternativas:

- Si se consideran justificadas, se introducirán las oportunas modificaciones antes de elevar el informe definitivo, no sin antes obtener la suficiente evidencia que soporte el cambio de posición.
- Si no se está conforme con los comentarios recibidos deberá señalarse esa circunstancia en el informe, añadiendo las observaciones de por qué no se aceptan las alegaciones del órgano auditado.

Una vez transcurrido el plazo concedido para que la Unidad auditada realice las alegaciones y no hubiere contestado, los auditores deberán elevar el borrador del informe a informe definitivo, haciendo constar especialmente en él las razones por las que no se incluyen las alegaciones.

Según la Guía 802 el Informe de Auditoría se puede presentar en formato audiovisual. No obstante, este informe siempre deberá entregarse en soporte papel y debidamente firmado, o bien en soporte electrónico con firma electrónica. El esquema del informe incluirá como mínimo:

- Fecha de emisión del informe
- Un apartado para el alcance, limitaciones al alcance, y objetivo de la auditoría, con la debida identificación del sistema auditado.

- Breve descripción del proceso metodológico aplicado para realizar la auditoría.
- Identificación de la documentación revisada.
- Identificación de la tipología de pruebas realizadas.
- Las fechas (de comienzo y final del trabajo de campo, ya sean reuniones como revisiones técnicas) en que se ha realizado el trabajo de auditoría
- Indicación de si ha habido alguna limitación en la realización de las pruebas o revisiones, que impidan dar una opinión sobre determinados elementos de seguridad.
- Una sección de informe ejecutivo resumiendo los aspectos más relevantes o las áreas de acción más significativas, con un resumen general del grado de cumplimiento.
- Las recomendaciones en ningún caso deberán ser cerradas, sino sugerencias de las distintas alternativas posibles, cuando sea aplicable, a considerar por los responsables de seguridad.
- Las recomendaciones estarán siempre basadas en la existencia de un riesgo y sustentadas debidamente, o bien relacionadas con un incumplimiento fehaciente y preciso de los requisitos básicos y mínimos del RD 3/2010.
- En anexos se podrán describir los detalles y resultados de las pruebas que permiten llegar a las conclusiones del informe ejecutivo, agrupándolos por los apartados del informe ejecutivo.
- El informe también podrá incluir como anexo las contestaciones del Responsable de Seguridad a los comentarios vertidos en el informe, o las acciones que se tomarán para solucionar las deficiencias, si las hubiera.
- El Informe de Auditoría deberá ser firmado por el jefe del equipo de auditoría, e indicar los participantes en el equipo de auditoría en un anexo o a continuación de la firma del jefe del equipo.

### 36.05. Bibliografía

A continuación se señalan las referencias bibliográficas empleadas para la preparación de este tema:

- Módulo "Auditoría y Sistemas de Información", II Curso de Auditorías de Sistemas de Información (INAP), impartido por Vicente Peirats Cuesta en 2006.
- Módulo "Método y Práctica de la Auditoría de Sistemas de Información", II Curso de Auditorías de Sistemas de Información (INAP), impartido por Fernando Rodríguez Rivadulla en 2006.
- Módulo "Confianza en los sistemas de información y Criterios de Seguridad, Normalización y Conservación de las aplicaciones usadas en el ejercicio de Potestades, II Curso de Auditorías de Sistemas de Información (INAP), impartido por Miguel Ángel Amutio Gómez en 2006.
- Information Systems Audit and Control Foundation: COBIT 5.0. [www.isaca.org](http://www.isaca.org)
- Normas generales para la Auditoría de Sistemas de Información de ISACA, Information System Audit and Control Association. [www.isaca.com](http://www.isaca.com)
- Páginas Web de ASIA, Asociación de Auditores y Auditoría y Control de Sistemas y Tecnologías de la Información y Comunicaciones de España, y Capítulo Español de ISACA. [www.auditoresdesistemas.com](http://www.auditoresdesistemas.com)
- Institute of Internal Auditors: Model Curriculum for Information System Auditing, Agosto 1992. ISBN 0-89413-274-1
- IGAE: Normas de Auditoría del Sector Público. [www.igae.pap.minhap.gob.es](http://www.igae.pap.minhap.gob.es)
- Instituto de Contabilidad y Auditoría de Cuentas: Norma Técnica de Auditoría sobre "la auditoría de cuentas en entornos informatizados". [www.icac.meh.es](http://www.icac.meh.es)
- Auditoría Informática, Un Enfoque Práctico 2ª Edición, Mario G. Piattini y Emilio del Peso, Editorial RA-MA. ISBN 8478972935
- Auditoría de los Sistemas de Información, Rafael Bernal Montañés y Óscar Coltell Simon, Editorial Universidad Politécnica de Valencia. ISBN 8477213933.
- Instituto de Auditores Internos de España, [www.iai.es](http://www.iai.es)
- Portal de la Administración electrónica: Información sobre los Esquema Nacionales de Seguridad de Interoperabilidad y Seguridad, [administracionelectronica.gob.es](http://administracionelectronica.gob.es)
- Instituto para el Gobierno de las Tecnologías de la Información. IT Governance Institute (ITGI), [www.itgi.org](http://www.itgi.org)

- 01CC - Auditoría y Calidad del Software – Curso 06/07 – Universidad de Murcia  
[dis.um.es/~jsaez/acs/curso0607/](http://dis.um.es/~jsaez/acs/curso0607/)
- Sans Institute: [www.sans.org](http://www.sans.org)
- Guía 802. Auditoría del Esquema Nacional de Seguridad: [www.ccn-cert.cni.es](http://www.ccn-cert.cni.es)
- Agencia Española de Protección de Datos: [www.agpd.es](http://www.agpd.es)
- Informe COSO: [www.auditool.org](http://www.auditool.org), [www.gerencie.com](http://www.gerencie.com),  
[www.monografias.com/trabajos12/coso/coso.shtml](http://www.monografias.com/trabajos12/coso/coso.shtml)